

Área de Conocimiento de Tecnología de la Información y Comunicación

Auditoría de Sistemas

Informe final de auditoría de redes en el SILAIS Sede Masaya, Nicaragua

Elaborado por:

Br. Gerson Antonio
Valdivia

Br. Haxell Antonio
Trejos Rodríguez

Br. Alison Michelle
Navarro Goussen

Br. Stephanie Lucía
Mora Chávez

Br. Arleth del Rosario
Velásquez Gómez

Docente:

Msc. Leonel Antonio Martínez Zuniga

13 de junio, 2026
Managua, Nicaragua

INDICE

I.	INTRODUCCIÓN	1
II.	OBJETIVOS DE LA AUDITORIA	2
	OBJETIVO GENERAL.....	2
	OBJETIVOS ESPECIFICOS.....	2
III.	ALCANCE DE LA AUDITORIA	3
IV.	METODOLOGÍA DE LA AUDITORÍA	4
V.	ÁREAS A AUDITAR.....	7
VI.	DETERMINACIÓN DE LOS PROCEDIMIENTOS DE CONTROL.....	9
VII.	RESUMEN DE LA INFRAESTRUCURA FÍSICA ACTUAL DE LA RED	11
VIII.	PRUEBAS TÉCNICAS PLANIFICADAS PARA LA RED	18
IX.	IDENTIFICACIÓN DE RIESGOS, AMENAZAS Y VULNERABILIDADES.....	24
X.	PRUEBAS REALIZADAS Y RESULTADOS	30
XI.	HALLAZGOS.....	54
XII.	NIVEL DE MADUREZ DE LOS PROCESOS DEL DOMINIO DSS	64
XIII.	RESUMEN Y CONCLUSIONES.....	70
XIV.	ANEXOS.....	73

I. INTRODUCCIÓN

El presente documento constituye el Informe Final de la Auditoría de Redes realizada en el SILAIS – Sede Masaya, entidad descentralizada del Ministerio de Salud de Nicaragua responsable de la vigilancia epidemiológica y la atención integral en salud del departamento de Masaya.

La auditoría tuvo como propósito evaluar el estado actual de la infraestructura física y la arquitectura lógica de la red de área local (LAN), verificando el cumplimiento de los procesos de gestión y seguridad establecidos en el dominio DSS (Entregar, Dar Servicio y Soporte) del marco de referencia COBIT 2019.

El alcance abarcó desde el nodo central de telecomunicaciones hasta los puntos de conexión de red en las estaciones de trabajo, excluyendo la evaluación del hardware de cómputo de los usuarios finales. Para la ejecución de las pruebas y la valoración de los hallazgos se aplicaron, de manera complementaria, los estándares ISO/IEC 27001:2022 (seguridad de la información), ANSI/TIA/EIA (cableado estructurado) e ISO 19011:2018 (directrices de auditoría).

El informe presenta los objetivos de la auditoría, el alcance, la metodología empleada, las pruebas realizadas y sus resultados, los hallazgos clasificados por área, la evaluación del nivel de madurez de los procesos DSS, las conclusiones generales y un plan de recomendaciones estratégicas priorizado.

II. OBJETIVOS DE LA AUDITORIA

OBJETIVO GENERAL

Realizar una Auditoria de Redes en la estructura física y lógica en el SILAIS - Sede Masaya, utilizando el marco de trabajo COBIT 2019 y su dominio DSS (Entregar, Dar Servicio y Soporte) y los procesos: DSS01 – Gestión de Operaciones, DSS02 – Gestión de Solicitudes e Incidentes, DSS03 – Gestión de Problemas, DSS04 – Gestión de la Continuidad y DSS05 – Gestión de Servicios de Seguridad a fin de identificar su estado actual y emitir recomendaciones necesarias que permitan a la institución mejorar su infraestructura.

OBJETIVOS ESPECIFICOS

- Realizar la planificación y programación de la auditoría de redes, estableciendo el organigrama del equipo auditor, el plan de trabajo y la asignación de recursos para la evaluación de la infraestructura física y lógica de la red.
- Ejecutar el diagnóstico técnico de la infraestructura de red, incluyendo la identificación de activos, amenazas, vulnerabilidades y la cuantificación de riesgos según la metodología ISO 27005.
- Evaluar la infraestructura física, la arquitectura lógica y la seguridad de la red mediante pruebas técnicas y verificación documental, contrastando los resultados con los criterios establecidos en el dominio DSS de COBIT 2019 y los estándares aplicables.
- Emitir un informe final de auditoría que contenga los hallazgos clasificados, la valoración del nivel de madurez de los procesos DSS, las conclusiones y un plan de recomendaciones priorizado para la mejora de la infraestructura de comunicaciones.

III. ALCANCE DE LA AUDITORIA

La auditoría abarcó la evaluación de la red de área local (LAN) del SILAIS – Sede Masaya, desde el nodo central de telecomunicaciones hasta los puntos de conexión en las áreas de trabajo, excluyendo el hardware de cómputo de los usuarios finales.

El marco de referencia fue el dominio DSS de COBIT 2019 (procesos DSS01 a DSS05), complementado con ANSI/TIA/EIA para cableado estructurado e ISO/IEC 27001:2022 para seguridad de las comunicaciones. La evaluación se realizó sobre la situación actual de la infraestructura al momento del trabajo de campo (abril-mayo 2026).

Componentes específicos del alcance:

- **Infraestructura de Hardware de Red:** Estado físico, capacidad y ubicación de los switches Fast Ethernet (3), UPS, condiciones ambientales y seguridad física.
- **Medios de Transmisión (Capa Física):** Cableado estructurado UTP Cat5e, conectores RJ45, canaletas plásticas, patch panels, rosetas de pared y patch cords.
- **Arquitectura Lógica y Seguridad:** Topología, direccionamiento IP, DHCP, segmentación (VLANs), velocidad de enlace, seguridad WiFi, conexiones privadas.
- **Gestión y Gobernanza:** Políticas de administración de red, inventario de activos, gestión de incidentes (DSS02), problemas (DSS03), continuidad (DSS04) y seguridad (DSS05).

IV. METODOLOGÍA DE LA AUDITORÍA

Para la ejecución de esta auditoría integral de infraestructura de red del SILAIS - Sede Masaya, se aplicarán técnicas de inspección ocular de la infraestructura física de comunicaciones, análisis de configuración lógica de los dispositivos de red, pruebas de conectividad y rendimiento, revisión documental de políticas y registros de gestión de red, y entrevistas estructuradas con el personal clave de las áreas funcionales. Las actividades operativas y las herramientas normativas a utilizar son:

El marco COBIT 2019, a través de su dominio DSS, establece los procesos de gobierno y gestión que deben implementarse para la entrega, soporte y seguridad de los servicios de TI. Define el "qué" debe hacerse a nivel de procesos (por ejemplo, DSS05 – Gestión de Servicios de Seguridad). Sin embargo, COBIT no detalla los controles técnicos específicos que deben aplicarse. Para ello, se utiliza de manera complementaria la norma ISO/IEC 27001:2022, que proporciona un catálogo detallado de controles de seguridad de la información (Anexo A), tales como los aplicables a la seguridad de las comunicaciones (A.13), el control de acceso (A.9) o la seguridad física (A.11). Ambos marcos son interoperables y su uso combinado es una práctica recomendada por ISACA e ISO, permitiendo auditar tanto la gobernanza como la implementación técnica de la seguridad.

Para esta auditoría se seleccionó exclusivamente el dominio DSS (Entregar, Dar Servicio y Soporte) de COBIT 2019 y sus cinco procesos (DSS01 a DSS05), por las siguientes razones:

1. **Pertinencia temática:** El dominio DSS aborda directamente la operación, el mantenimiento, la seguridad y la continuidad de los servicios de TI, que constituyen el foco central de esta auditoría de infraestructura de red.
2. **Alineación con los hallazgos preliminares:** El diagnóstico inicial reveló que las mayores deficiencias del SILAIS se concentraban en los procesos operativos y de seguridad, todos ellos cubiertos por el dominio DSS.

Levantamiento del mapa topológico físico y lógico de la red del SILAIS Masaya para contrastarlo con la documentación existente, identificando la interconexión de los tres switches Fast Ethernet de 24 puertos no administrables, la topología en estrella, la distribución de puntos de red hacia las catorce áreas funcionales, la ubicación y configuración de los puntos de acceso inalámbrico que dan servicio a las áreas con dependencia de conectividad WiFi (Estadística, Contabilidad, Insumos

Médicos, Enfermería, RRHH y Dirección), y el trazado de las conexiones privadas en Sindicato, SNC y Transporte.

Ejecución de un Checklist de inspección física en los nodos de comunicaciones, verificando las condiciones de seguridad física y la ausencia de rack o gabinete cerrado. Se inspeccionará el estado de los switches Fast Ethernet, el ordenamiento de cables y la ausencia de patch panels. Se realizará una auditoría de infraestructura física certificada bajo estándares ANSI/TIA-569 y TIA-606, respaldada con registro fotográfico de alta resolución y verificación de etiquetado con rotuladoras industriales, en el marco de los procesos DSS01 (Gestión de Operaciones) y DSS05 (Gestión de Servicios de Seguridad).

Inspección técnica del cableado estructurado en las catorce áreas funcionales, verificando la categoría del cableado UTP instalado, el cumplimiento de la norma de ponchado T568A en los conectores RJ45, la presencia o ausencia de canaletas plásticas de protección, la existencia de rosetas de pared y patch panels, el uso de patch cords flexibles, la rotulación de puntos de red y las condiciones físicas de las rutas de cableado, contrastando los hallazgos con los estándares ANSI/TIA/EIA-568-C, ANSI/TIA/EIA-569-C y ANSI/TIA/EIA-606-B, en el marco del proceso DSS01 (Gestión de Operaciones).

Pruebas de conectividad y verificación de velocidad de enlace en puntos de red de áreas críticas y de uso compartido, utilizando comandos de red (ipconfig /all, propiedades del adaptador) para determinar la velocidad real de negociación de las tarjetas de red con los switches Fast Ethernet, confirmar la operación a 100 Mbps y cuantificar el nivel de estrangulamiento operativo documentado en el diagnóstico preliminar, en el marco del proceso DSS01 (Gestión de Operaciones).

Análisis de configuración lógica de la red, incluyendo la verificación del esquema de direccionamiento IP y la asignación DHCP mediante comandos ipconfig /all en equipos de diferentes áreas funcionales, la comprobación de la topología de red plana sin segmentación VLAN mediante pruebas de ping entre equipos de áreas con diferentes niveles de sensibilidad de datos (Varios 1 a Epidemiología, Varios 1 a Banco Biológico), y la verificación de la ausencia de listas de control de acceso, políticas de calidad de servicio y mecanismos de seguridad de puertos que restrinjan la comunicación entre áreas, en el marco del proceso DSS05 (Gestión de Servicios de Seguridad).

Evaluación de la seguridad de la red inalámbrica en las áreas con dependencia de conectividad WiFi (Estadística, Contabilidad, Insumos Médicos, Enfermería, RRHH y Dirección), verificando los protocolos de cifrado implementados (WPA2, WPA3), los mecanismos de autenticación utilizados, la intensidad de señal en los puntos de trabajo críticos mediante herramientas de análisis WiFi, y la existencia de medidas de control

de acceso a la red inalámbrica, en el marco del proceso DSS05 (Gestión de Servicios de Seguridad).

Verificación de las conexiones privadas a Internet en Sindicato, SNC y Transporte, documentando el tipo de conexión, proveedor de servicios, medidas de seguridad implementadas, grado de integración con la red corporativa del SILAIS, y evaluación de los riesgos de fuga de información a través de estos canales no monitoreados por la administración de TI, en el marco del proceso DSS05 (Gestión de Servicios de Seguridad).

Revisión de la gestión de servicios de red utilizando los lineamientos de los procesos del dominio DSS de COBIT 2019, documentando la existencia o ausencia de: políticas de operación (DSS01), procedimientos de registro y resolución de incidentes de conectividad (DSS02), análisis de problemas recurrentes de red (DSS03), planes de continuidad operativa (DSS04), y controles de seguridad implementados en la red (DSS05).

Evaluación de la gestión de riesgos tecnológicos basándose en los procesos DSS03 (Gestión de Problemas) y DSS05 (Gestión de Servicios de Seguridad) de COBIT 2019, verificando si la Alta Dirección del SILAIS ha establecido un proceso formal para la identificación, análisis y tratamiento de los riesgos asociados a la obsolescencia tecnológica de los switches, la topología de red plana y la dependencia de conectividad inalámbrica en áreas críticas.

Revisión de la seguridad lógica y protección de los datos en tránsito, basándose en el proceso DSS05 (Gestión de Servicios de Seguridad) de COBIT 2019, verificando la existencia de controles de acceso a la red, mecanismos de autenticación para la conexión de dispositivos, y medidas de protección para la transmisión de datos epidemiológicos hacia el MINSA Central.

Evaluación del nivel de madurez de los procesos del dominio DSS de COBIT 2019 aplicables a la infraestructura de red del SILAIS Masaya, utilizando la escala de capacidad de procesos de 0 a 5, para cada uno de los procesos evaluados: DSS01, DSS02, DSS03, DSS04 y DSS05.

V. ÁREAS A AUDITAR

Para dar cumplimiento al alcance definido, se auditó la conectividad de red en las 14 áreas funcionales del SILAIS – Sede Masaya. La tabla siguiente presenta la distribución de equipos, el tipo de conectividad (LAN, WLAN o Conexión Privada) y la criticidad de los datos procesados en cada área, lo cual fundamenta la priorización de las pruebas y los hallazgos reportados.

Área Funcional	Equipos Escritorio	Laptops	Tipo Conectividad	Datos Sensibles Procesados
Epidemiología	6	0	100% LAN	Datos SISNIVEN, brotes, mortalidad
Varios 1	10	0	LAN (Switch 24p)	Información general/diversa
Varios 2	3	0	2 LAN, 1 WLAN	Información general/diversa
Varios 3	4	0	100% LAN	Información general/diversa
Estadística	3	0	1 LAN, 2 WLAN	Datos estadísticos SISNIVEN, boletines
Contabilidad	3	0	100% WLAN	Información financiera, nóminas
RRHH	3	0	2 WLAN, 1(implícito)	Datos personales de personal sanitario

Área Funcional	Equipos Escritorio	Laptops	Tipo Conectividad	Datos Sensibles Procesados
Insumos Médicos	3	0	100% WLAN	Inventario farmacéutico, caducidades
Enfermería	2	0	100% WLAN	Protocolos de atención, turnos
Dirección/FET Salud	1	2	1 LAN, 2 WLAN	Información estratégica confidencial
SNC	2	2	Conexión Privada	Datos de salud comunitarios sensibles
Administración	1	0	LAN	Información presupuestaria
Caja	2	0	LAN	Transacciones financieras
Banco Biológico	1	0	LAN	Muestras biológicas, resultados VIH/TB
Sindicato	2	0	Conexión Privada	Información gremial
Transporte	0	1	Conexión Privada	Logística operativa
TOTAL	46	5		

VI. DETERMINACIÓN DE LOS PROCEDIMIENTOS DE CONTROL

Infraestructura física de red

- Todos los equipos de comunicaciones (switches, puntos de acceso, routers) deben de estar alojados en armarios o racks cerrados con llave, protegidos de manipulación accidental y condiciones ambientales adversas.
- Cada componente de red debe de estar correctamente identificado y documentado, con número de serie, fecha de adquisición, garantía y ubicación físicas registradas en un inventario actualizado.
- El cableado estructurado debe de estar protegido con canaletas plásticas en todas las áreas funcionales, respetando radios de curvatura y sin tensión mecánica.
- Todos los puntos de red deben de terminar en rosetas de pared normalizadas, y la conexión final debe de realizarse mediante patch cords flexibles de fábrica.
- Los switches y las UPS deben de contar con un programa documentado de mantenimiento preventivo, con registro de fechas, problemas detectados, soluciones aplicadas y fecha del próximo mantenimiento.

Arquitectura lógica y segmentación de la red

- La red LAN debe de estar segmentada mediante VLANs, separando lógicamente el tráfico de áreas críticas (Epidemiología, Banco Biológico) del tráfico administrativo y de áreas de uso compartido.
- Se deben de implementar Listas de Control de Acceso (ACLs) entre VLANs para restringir la comunicación únicamente a lo estrictamente necesario para la operación de los servicios.
- La velocidad de negociación de los enlaces debe de ser monitoreada y se debe de garantizar que los dispositivos de conmutación no representen un cuello de botella para las aplicaciones críticas.
- La red inalámbrica debe de utilizar protocolos de cifrado WPA3 (o WPA2-Enterprise como mínimo) y debe de contar con segmentación que aisle el tráfico WiFi de la red corporativa interna.
- Las conexiones privadas a Internet en dependencias externas deben de estar formalmente autorizadas, documentadas e integradas a la red corporativa mediante una VLAN de invitados que impida el acceso a la LAN interna.

Gestión de operaciones y mantenimiento de la red

- Deben de existir procedimientos formales para la gestión de incidentes de red, registrando cada fallo en una bitácora o sistema de tickets con seguimiento hasta su resolución.
- Ante incidentes recurrentes, se debe de realizar un análisis de causa raíz documentado para implementar soluciones definitivas y evitar su repetición.
- Las configuraciones de los switches y puntos de acceso deben de estar documentadas y respaldadas, y se debe de aplicar un procedimiento de control de cambios que requiera autorización previa y registro.
- Se debe de monitorear continuamente el rendimiento y la disponibilidad de la red, y se deben de generar informes periódicos de desempeño para la Dirección.
- La gestión de activos de red debe de ser formal; se debe de conocer la antigüedad y el ciclo de vida de cada equipo, y debe de existir un plan de renovación tecnológica aprobado.

Continuidad del servicio de red

- Debe de existir un Plan de Continuidad y Recuperación ante Desastres (DRP) para la infraestructura de comunicaciones, que contemple escenarios de fallo de switches, del enlace con MINSA Central y de cortes de energía.
- El plan debe de definir los objetivos de tiempo de recuperación (RTO) y punto de recuperación (RPO), debe de asignar responsables y se debe de probar periódicamente mediante simulacros.
- Se debe de disponer de un switch de respaldo para los equipos críticos, y la configuración del mismo se debe de mantener documentada y lista para su activación.
- Las UPS deben de contar con mantenimiento programado y se debe de verificar trimestralmente su autonomía; las baterías deben de ser reemplazadas antes del fin de su vida útil estimada.

VII. RESUMEN DE LA INFRAESTRUCTURA FÍSICA ACTUAL DE LA RED

Componente	Especificación Técnica
Router de Borde	Router de Servicios Empresariales Huawei AR1220E Dimensiones (ancho × profundidad × altura): 220 × 300 × 44 mm Peso: 2.1 kg Rendimiento: Throughput de hasta 200 Mbps con servicios básicos Usuarios concurrentes soportados: 50-100 Interfaces WAN: 2 puertos Gigabit Ethernet (GE) eléctricos, configurables como WAN Interfaces LAN: 8 puertos Fast Ethernet (FE) de 100 Mbps Memoria RAM: 512 MB Memoria Flash: 256 MB Protocolos de enrutamiento: Estático, RIP, OSPF básico Servicios de red: Servidor/Cliente/Relay DHCP, DNS Proxy, NAT/PAT Seguridad: Firewall de Inspección de Estado (SPI), Listas de Control de Acceso (ACLs), filtrado por URL básico. Calidad de Servicio (QoS): Clasificación de tráfico por puerto, DSCP y dirección IP con colas de prioridad (PQ, WRR). Capacidad de limitación de ancho de banda por IP Gestión: Interfaz web (HTTP/HTTPS), CLI vía Telnet/SSH, SNMP v1/v2c Alimentación: Fuente de poder externa, 100-240V AC, 50/60 Hz Consumo energético máximo: 25 W Temperatura de funcionamiento: 0 °C a 45 °C Humedad relativa de funcionamiento: 5% a 90% (sin condensación) Tipo de conector: RJ45 metálico en todos los puertos

Componente	Especificación Técnica
	Indicadores LED: Alimentación (Power), Actividad (Activity) por puerto
Switches	Switches Principales y secundario (TP-Link TL-SF1024D) Switch Ethernet Fast Ethernet no gestionable de 24 puertos, ubicado en el área de Dirección. Especificaciones físicas Dimensiones (ancho × profundidad × altura): 294 × 180 × 44 mm Peso: 1.5 kg Carcasa del switch: Metal Especificaciones técnicas Descripción del modelo: TP-Link Switch de 24 puertos 10/100 Mbps no administrable (TL-SF1024D) Velocidad: Fast Ethernet (10/100 Mbps) Número de puertos: 24 puertos RJ45 10/100 Mbps Tipo de conector: RJ45 metálico Indicadores LED: Alimentación (Power) y Enlace/Actividad (Link/Act) por puerto Compatibilidad con Jumbo Frame: 10 KB Tamaño de tabla MAC: 8K Tamaño de búfer integrado: 2 Mbits Capacidad de Conmutación (Fabric): 4.8 Gbps Throughput de paquetes: 3.57 Mpps a 64 bytes Método de transmisión: Store-and-Forward (Almacenamiento y Reenvío) Estándares soportados: IEEE 802.3 (Ethernet), IEEE 802.3u (Fast Ethernet), IEEE 802.3x (Control de Flujo Full-Dúplex). No soporta IEEE

Componente	Especificación Técnica
	802.1Q (VLANs) Características: Auto MDI/MDIX (no requiere cable cruzado). Control de flujo Full-Dúplex. Ventilación pasiva (sin ventilador) Alimentación: Fuente interna 100-240V AC, 50/60 Hz. Consumo máximo: 7 W Nivel de ruido acústico: 0 dBA (sin ventilador) Temperatura de funcionamiento: 0 °C a 40 °C MTBF (a 25 °C): > 100,000 horas Cumplimiento de normativas: FCC Clase A, CE, RoHS
Cableado Estructurado	Cableado Estructurado UTP (General Cable Cat5e) Cable de par trenzado sin blindaje (U/UTP) Categoría 5e, instalado en las 14 áreas funcionales del SILAIS. Especificaciones físicas Tipo de cable: U/UTP (sin blindaje global, pares sin blindaje individual) Calibre del conductor: 24 AWG (0.51 mm de diámetro), conductor de cobre sólido Número de pares: 4 pares trenzados (8 hilos) Código de colores: Blanco-Naranja/Naranja, Blanco-Verde/Verde, Blanco-Azul/Azul, Blanco-Marrón/Marrón Cubierta exterior: PVC (Cloruro de Polivinilo) color gris, clasificación CM/CMR Diámetro exterior del cable: 5.0 mm Norma de ponchado: T568A en ambos extremos (configuración de cable recto o "straight-through") Etiquetado de cables: No implementado en la mayoría de las áreas

Componente	Especificación Técnica
	Especificaciones técnicas Categoría ANSI/TIA: Categoría 5e (enhanced) Ancho de banda: 100 MHz Velocidad máxima soportada: 1000BASE-T (Gigabit Ethernet) hasta 100 metros, según IEEE 802.3ab. Compatible con 10/100 Mbps Impedancia característica: $100 \pm 15 \Omega$ Atenuación (a 100 MHz): ≤ 22.0 dB por 100 metros NEXT (Near End Crosstalk, a 100 MHz): ≥ 30.1 dB Pérdida de retorno (a 100 MHz): ≥ 20.0 dB Conectores RJ45: 8 posiciones 8 contactos (8P8C), categoría 5e, con contacto dorado de 50 micropulgadas Canaletas plásticas de protección: Presentes únicamente en 4 de las 14 áreas funcionales (Banco Biológico, Sindicato, Dirección y FET Salud)
Ponchado	Norma T568A en ambos extremos (cable directo)
Topología	Estrella
UPS	Forza FNT-1002 Sistema de Alimentación Ininterrumpida (UPS) de topología Stand-by, ubicado uno por cada switch para protección contra cortes de energía. Especificaciones físicas Dimensiones (ancho × profundidad × altura): 140 × 365 × 165 mm Peso: 5.2 kg Gabinete: Plástico compacto, formato tipo escritorio/torre

Componente	Especificación Técnica
	Tomas de salida: 4-6 tomas NEMA 5-15R (estándar americano) con respaldo de batería y supresión de picos Especificaciones técnicas Descripción del modelo: UPS Forza FNT-1002 (1000 VA / 600 W) o equivalente Topología: Stand-by (Offline). Tiempo de conmutación a batería: 2-6 ms Capacidad de potencia aparente: 1000 VA Capacidad de potencia activa: 600 W Regulación de Voltaje: AVR (Regulador Automático de Voltaje) de 2 etapas (Refuerzo y Reducción). Corrige fluctuaciones sin usar batería Batería: 1 batería interna sellada de plomo-ácido (VRLA), 12 V / 7 Ah. Libre de mantenimiento Autonomía estimada: 10-15 minutos con carga típica de 40 W (3 switches). Suficiente solo para apagado seguro Supresión de picos: Protección contra sobretensión de 390 Joules Protecciones: Cortocircuito, sobrecarga, sobredescarga de batería Interfaz de gestión: No dispone de puerto USB ni SNMP para monitoreo o apagado automático Alimentación de entrada: 100-140 VAC, 50/60 Hz Tiempo de recarga de batería: 6-8 horas al 90% de capacidad Indicadores: LED de alimentación, modo batería y fallo Temperatura de funcionamiento: 0 °C a 40 °C Humedad relativa de funcionamiento: 0% a 90% (sin condensación) Observación: La autonomía es limitada y está dimensionada únicamente para los switches. La ausencia de un puerto de gestión impide el apagado automático al agotarse la batería.

Componente	Especificación Técnica
Etiquetado de Cables	Sin etiquetado de cable
Gabinete / Rack	No existe
Canaletas Plásticas	Instalación parcial
Rosetas de Pared	No se utilizan
Patch Panels	No se utilizan
Patch Cords	No se utilizan
Puntos de Acceso Inalámbrico	TP-Link TL-WA801N Puntos de Acceso WiFi de banda única 2.4 GHz, estándar 802.11n (WiFi 4), utilizados para dar servicio inalámbrico a las áreas críticas. Especificaciones físicas Dimensiones (ancho × profundidad × altura): 181 × 125 × 36 mm Peso: 0.3 kg (sin inyector PoE) Antenas: 2 antenas fijas omnidireccionales de 5 dBi de ganancia, no desmontables Especificaciones técnicas Descripción del modelo: TP-Link Punto de Acceso Inalámbrico N 300 Mbps (TL-WA801N) Estándar WiFi: IEEE 802.11n (WiFi 4). Retrocompatible con 802.11b/g Banda de frecuencia: 2.4 GHz única Velocidad máxima teórica: 300 Mbps en capa física (rendimiento real TCP/IP: 60-80 Mbps en condiciones óptimas) Tecnología MIMO: 2x2 (Múltiple Entrada, Múltiple Salida)

Componente	Especificación Técnica
	Modos de operación: Punto de Acceso (AP), Extensor de Rango, Cliente. Actualmente en modo AP Seguridad inalámbrica: WPA/WPA2-PSK (Personal) y Enterprise. Cifrado TKIP y AES. Filtrado de direcciones MAC Interfaces cableadas: 1 puerto Fast Ethernet RJ45 10/100 Mbps Alimentación: PoE Pasivo 24V (inyector incluido en paquete). No compatible con PoE estándar 802.3af/at Gestión: Interfaz web de configuración. Sin soporte para gestión centralizada (sin controladora) Áreas de cobertura: Estadística (2), Contabilidad (3), RRHH (2), Insumos Médicos (3), Enfermería (2), Dirección (2 laptops) Potencia de transmisión: < 20 dBm (100 mW) Sensibilidad de recepción: -74 dBm a 300 Mbps; -90 dBm a 1 Mbps Temperatura de funcionamiento: 0 °C a 40 °C
Segmentación de Red	No implementada
Conexiones Privadas	Sindicato, SNC y Transporte

VIII. PRUEBAS TÉCNICAS PLANIFICADAS PARA LA RED

Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo	Componente del Alcance
Continuidad de cableado (muestra representativa de puntos de red)	Tester de Cableado UTP RJ45 (Generador y receptor de tonos). Empleado para verificar mapeo de pines de extremo a extremo.	8 pines con continuidad en ambos extremos según norma T568A	Conexiones intermitentes o nulas en áreas críticas	Medios de Transmisión (Capa Física)
Norma de ponchado	Inspección visual del código de colores + Tester RJ45. Verificación del orden Blanco/Naranja-Naranja, etc., en los conectores de plástico transparente.	Secuencia T568A correcta en ambos extremos del cable	Problemas de velocidad, errores de trama, negociación a 100 Mbps o inferior	Medios de Transmisión (Capa Física)
Velocidad de negociación de enlace	Herramientas del SO e interfaces CLI: Comandos de consola (Get-NetAdapter en	Velocidad de enlace: 100 Mbps (limitada por switches Fast Ethernet)	Confirmación de estrangulamiento operativo documentado en diagnóstico	Infraestructura de Hardware de Red / Arquitectura Lógica y Seguridad de

Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo	Componente del Alcance
	PowerShell, ipconfig /all) y revisión en la tarjeta de red de la estación de trabajo.			Red
Asignación DHCP	Analizador de Protocolos de Software (Wireshark) ejecutado desde una laptop para capturar el tráfico de asignación, y comandos ipconfig /release y /renew.	IP en el rango correcto (.2 a .10 Dirección / .50 a .70 Lab), y DNS apuntando a Cloudflare (1.1.1.3).	Sin conectividad a red local o Internet	Arquitectura Lógica y Seguridad de Red
Verificación de dominio de broadcast	Escáneres de Red LAN (Advanced IP Scanner) ejecutados desde el laboratorio para mapear la visibilidad de los equipos conectados.	Todos los equipos en mismo dominio de broadcast (red plana)	Confirmación de ausencia de segmentación VLAN	Arquitectura Lógica y Seguridad de Red

Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo	Componente del Alcance
Conectividad entre áreas funcionales	Ejecución de ping y escaneo de puertos desde una PC del laboratorio hacia la IP de la Dirección (192.168.50.2).	Comunicación sin restricciones entre todas las áreas (red plana)	Confirmación de vulnerabilidad de movimiento lateral sin barreras	Arquitectura Lógica y Seguridad de Red
Prueba de saturación de switches Fast Ethernet	Utilidad de medición de Throughput (iPerf3) ejecutada en modelo cliente-servidor temporal entre dos laptops, midiendo el ancho de banda TCP/UDP.	Observación de degradación de rendimiento con tráfico concurrente	Estrangulamiento de aplicaciones críticas (SISNIVEN) en horas pico	Infraestructura de Hardware de Red
Seguridad de red inalámbrica	Comandos nativos (netsh wlan show networks) para auditar si el Router ISP está emitiendo señal WiFi abierta o con cifrado débil.	Si hay WiFi, debe usar cifrado WPA2 o superior, con contraseñas robustas.	Exposición de datos sensibles en áreas con dependencia WiFi	Arquitectura Lógica y Seguridad de Red

Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo	Componente del Alcance
Estado de UPS de switches	Prueba de autonomía manual (Drop Test): Desconexión controlada del suministro eléctrico de la UPS de 1000VA y cronometraje del tiempo de respaldo.	Batería con capacidad de respaldo mínimo de 15 minutos	Caída inmediata de switches ante fluctuación eléctrica; riesgo de daño a equipos	Infraestructura de Hardware de Red
Estado físico de switches Fast Ethernet	Inspección física, Revisión táctil/visual de temperatura, acumulación de polvo y estado de las luces LED en el escritorio de madera.	Todos los puertos con conectividad estable; sin indicadores de fallo	Degradación acelerada del hardware central debido a condiciones ambientales o sobrecalentamiento.	Infraestructura de Hardware de Red
Verificación de canaletas y protección de cableado	Inspección ocular certificada con registro fotográfico. Levantamiento de evidencias sobre el uso de grapas, cableado directo a los	Cableado protegido en canaletas; ausencia de cables expuestos a tensión mecánica	Daño físico al cableado; interrupción de conectividad en áreas no protegidas	Medios de Transmisión (Capa Física)

Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo	Componente del Alcance
	equipos y etiquetas de masking tape.			
Verificación de conexiones privadas (Sindicato, SNC, Transporte)	Entrevista, inspección de equipos de conectividad	Documentación de tipo de conexión, proveedor, y medidas de seguridad	Fuga de información no monitoreada; bypass de controles de seguridad corporativos	Arquitectura Lógica y Seguridad de Red / Gestión y Gobernanza de la Red
Verificación de existencia de patch panels	Inspección visual en nodos de Dirección y Varios 1	Presencia de patch panels para terminación mecánica del cableado horizontal	Tensión en puertos de switches; daño a conectores; dificultad para mantenimiento	Medios de Transmisión (Capa Física)
Verificación de rosetas de pared	Inspección visual en áreas de trabajo	Presencia de rosetas o faceplates con jacks RJ45 hembra en cada punto de red	Conectores RJ45 expuestos a tensión y daño físico; fallos de conectividad	Medios de Transmisión (Capa Física)
Verificación de patch cords	Inspección visual en áreas de trabajo	Uso de patch cords flexibles de fábrica entre roseta y equipo final	Uso de cable sólido horizontal para conexión final; rotura de conductores	Medios de Transmisión (Capa Física)

Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo	Componente del Alcance
Revisión de Inventario de Activos de Red	Análisis documental y conciliación física (Checklist).	Inventario actualizado que coincida 100% con los equipos físicos, incluyendo número de serie y ubicación.	Pérdida de activos, desconocimiento del ciclo de vida y dificultad para planificar renovaciones.	Gestión y Gobernanza de la Red
Auditoría de Bitácora de Incidentes y Mantenimiento	Análisis documental y entrevistas con el personal de soporte.	Existencia de registros históricos de fallos, soluciones aplicadas (causa raíz) y mantenimientos de UPS/Switches.	Imposibilidad de prevenir fallos recurrentes; soporte técnico puramente reactivo y deficiente.	Gestión y Gobernanza de la Red
Verificación de copias de seguridad de configuraciones	Entrevista y solicitud de archivos de respaldo (Backups) del Router y Puntos de Acceso.	Existencia de archivos de configuración actualizados almacenados en un medio seguro fuera del equipo.	Imposibilidad de restablecer rápidamente la red tras el reemplazo de un router o AP dañado.	Gestión y Gobernanza de la Red
Verificación de infraestructura de contingencia (DRP)	Análisis documental y revisión de inventario de	Existencia de un plan DRP documentado y presencia física	Tiempos de inactividad prolongados (días) en caso de	Gestión y Gobernanza de la Red

Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo	Componente del Alcance
	bodega (Inspección visual).	de un switch de respaldo (repuesto en frío).	quemarse el switch principal.	

IX. IDENTIFICACIÓN DE RIESGOS, AMENAZAS Y VULNERABILIDADES

Amenaza	Vulnerabilidad(es)	Riesgo
A-RED-001: Fluctuaciones eléctricas y apagones	V-RED-005: UPS sin verificación periódica de baterías	R-RED-007: Caída de switches por agotamiento de baterías de UPS.
A-RED-002: Acumulación de polvo ambiental	V-RED-004: Ausencia de rack o gabinete de telecomunicaciones	R-RED-008: Fallo prematuro de switches por acumulación de polvo ambiental.
A-RED-003: Humedad relativa elevada (70-85%)	V-RED-004: Ausencia de rack o gabinete de telecomunicaciones	R-RED-013: Degradación de contactos y conectores por oxidación.
	V-RED-006: Cableado sin canaletas de protección	
A-RED-004: Acceso físico no controlado a puertos de red	V-RED-004: Ausencia de rack o gabinete de telecomunicaciones	R-RED-011: Conexión de dispositivos no autorizados a la red.

	V-RED-013: Falta de control de acceso a la red (802.1X)	
	V-RED-018: Falta de políticas de seguridad de la red	
A-RED-005: Fallo catastrófico de los Switches Principales por obsolescencia	V-RED-001: Switches Fast Ethernet obsoletos y no administrables	R-RED-001: Colapso total de la red LAN por fallo catastrófico.
	V-RED-003: Punto único de falla en el Switch Principal	
	V-RED-015: Falta de documentación y respaldo de configuraciones	
	V-RED-017: Inexistencia de Plan de Continuidad para la red	
A-RED-006: Daño físico al cableado estructurado	V-RED-006: Cableado sin canaletas de protección	R-RED-009: Interrupción de conectividad por daño al cableado expuesto.
	V-RED-007: Ausencia de patch panels y patch cords	
	V-RED-008: Ausencia de rosetas de pared	

A-RED-007: Ransomware dirigido al sector salud	V-RED-001: Switches Fast Ethernet obsoletos y no administrables	R-RED-002: Cifrado de datos epidemiológicos por ransomware en red plana.
	V-RED-002: Topología de red plana sin VLANs	
	V-RED-013: Falta de control de acceso a la red (802.1X)	
	V-RED-014: Ausencia de monitoreo de tráfico	
A-RED-008: Exfiltración de datos de pacientes del SISNIVEN	V-RED-002: Topología de red plana sin VLANs	R-RED-003: Violación masiva de confidencialidad de datos del Banco Biológico.
	V-RED-014: Ausencia de monitoreo de tráfico	
	V-RED-021: Datos SISNIVEN sin cifrado en tránsito	
A-RED-009: Ataque Man-in-the-Middle (MitM) en red WiFi	V-RED-010: Dependencia WiFi sin redundancia cableada	R-RED-004: Interceptación de credenciales y datos vía WiFi.
	V-RED-011: Seguridad WiFi no documentada	
	V-RED-021: Datos SISNIVEN sin cifrado en tránsito	

A-RED-010: Tormenta de broadcast (Broadcast Storm)	V-RED-001: Switches Fast Ethernet obsoletos y no administrables	R-RED-005: Parálisis total de la red por tormenta de broadcast.
	V-RED-002: Topología de red plana sin VLANs	
	V-RED-014: Ausencia de monitoreo de tráfico	
	V-RED-017: Inexistencia de Plan de Continuidad para la red	
A-RED-011: Propagación de malware por movimiento lateral	V-RED-001: Switches Fast Ethernet obsoletos y no administrables	R-RED-012: Infección de equipos críticos por movimiento lateral de malware.
	V-RED-002: Topología de red plana sin VLANs	
	V-RED-013: Falta de control de acceso a la red (802.1X)	
	V-RED-014: Ausencia de monitoreo de tráfico	
A-RED-012: Uso indebido de conexiones privadas	V-RED-012: Conexiones privadas fuera del perímetro de seguridad	R-RED-010: Fuga de información institucional a través de conexiones no monitoreadas.

	V-RED-018: Falta de políticas de seguridad de la red	
A-RED-013: Error humano en configuración de dispositivos de red	V-RED-007: Ausencia de patch panels y patch cords	R-RED-014: Interrupción de conectividad por error de configuración.
	V-RED-015: Falta de documentación de configuraciones	
	V-RED-016: Ausencia de responsable formal de administración de red	
	V-RED-020: Alta rotación de personal en cargos clave	
A-RED-014: Exposición involuntaria de datos por uso de WiFi no seguro	V-RED-010: Dependencia WiFi sin redundancia cableada	R-RED-006: Transmisión de datos sensibles a través de WiFi con cifrado débil.
	V-RED-011: Seguridad WiFi no documentada	
	V-RED-019: Personal sin capacitación en ciberseguridad	
A-RED-015: Sabotaje interno por personal	V-RED-004: Ausencia de rack o gabinete de telecomunicaciones	R-RED-016: Daño intencional a la infraestructura de red.
	V-RED-016: Ausencia de responsable formal de administración de red	

	V-RED-020: Alta rotación de personal en cargos clave	
A-RED-016: Ingeniería social telefónica	V-RED-016: Ausencia de responsable formal de administración de red	R-RED-015: Compromiso de credenciales de acceso a la red.
	V-RED-018: Falta de políticas de seguridad de la red	
	V-RED-019: Personal sin capacitación en ciberseguridad	

PRUEBAS REALIZADAS Y RESULTADOS

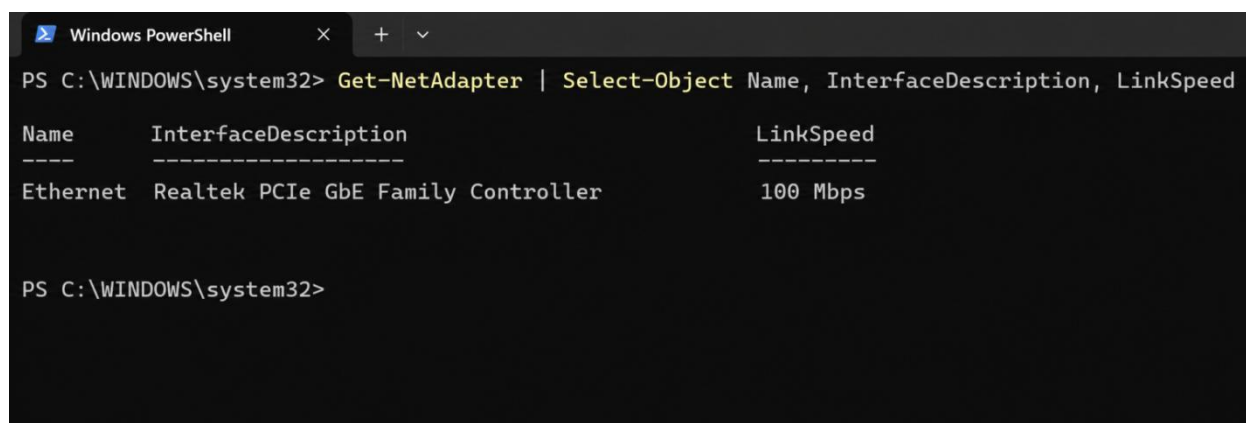
Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo
Continuidad de cableado (muestra representativa de puntos de red)	Tester de Cableado UTP RJ45 (Generador y receptor de tonos). Empleado para verificar mapeo de pines de extremo a extremo.	8 pines con continuidad en ambos extremos según norma T568A	Conexiones intermitentes o nulas en áreas críticas

Análisis de Continuidad Física y Condiciones Ambientales del Hardware



Se realizaron pruebas de continuidad en la capa física de la red utilizando un probador de cableado estructurado (LAN Cable Tester). Las lecturas de los instrumentos confirmaron una continuidad eléctrica adecuada (pines 1 al 8) en los segmentos UTP evaluados.

Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo
Velocidad de negociación de enlace	Herramientas del SO e interfaces CLI: Comandos de consola (Get-NetAdapter en PowerShell, ipconfig /all) y revisión en la tarjeta de red de la estación de trabajo.	Velocidad de enlace: 100 Mbps (limitada por switches Fast Ethernet)	Confirmación de estrangulamiento operativo documentado en diagnóstico



```

Windows PowerShell
PS C:\WINDOWS\system32> Get-NetAdapter | Select-Object Name, InterfaceDescription, LinkSpeed

Name      InterfaceDescription      LinkSpeed
----      -
Ethernet  Realtek PCIe GbE Family Controller  100 Mbps

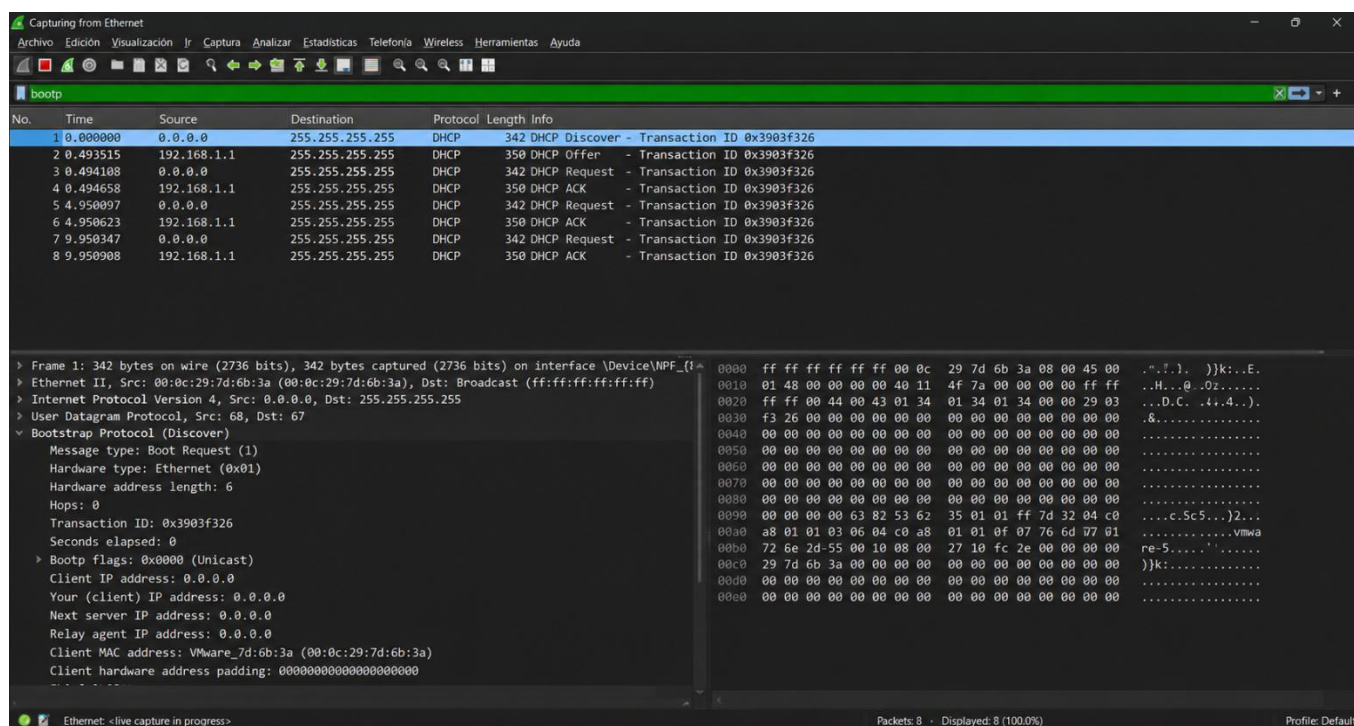
PS C:\WINDOWS\system32>

```

Se ejecutaron pruebas de diagnóstico a nivel de capa de enlace (Capa 2 del modelo OSI) utilizando la consola PowerShell (comando `Get-NetAdapter`) en estaciones de trabajo ubicadas en áreas críticas (Epidemiología/Estadística). La evidencia técnica confirma que, aunque las estaciones de trabajo cuentan con tarjetas de red con capacidad Gigabit (1000 Mbps), la velocidad de negociación del enlace (LinkSpeed) se encuentra forzada y estancada a **100 Mbps**. Este resultado constata físicamente el estrangulamiento operativo crónico generado por la obsolescencia de los Switches Fast Ethernet no administrables, lo que ralentiza la transmisión de datos al SISNIVEN e impacta directamente en el cumplimiento del proceso DSS01 (Gestión de Operaciones) de COBIT 2019.

Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo
Asignación DHCP	Analizador de Protocolos de Software (Wireshark) ejecutado desde una laptop para capturar el tráfico de asignación, y comandos ipconfig /release y /renew.	IP en el rango correcto (.2 a .10 Dirección / .50 a .70 Lab), y DNS apuntando a Cloudflare (1.1.1.3).	Sin conectividad a red local o Internet

1. Configuración del Filtro de Captura



2. Forzar el proceso DHCP

```

C:\WINDOWS\system32\cmd. x
C:\Users\gerso>ipconfig /release

Windows IP Configuration

Ethernet adapter Ethernet:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::b8e8:890f:98c3:9c4e%10
    Default Gateway . . . . . : 

Wireless LAN adapter Wi-Fi:

    Connection-specific DNS Suffix  . : 
    IPv6 Address. . . . . : 2803:2d60:1110:19e8::4
    Temporary IPv6 Address. . . . . : 2803:2d60:1110:19e8:724f:e61e:2dc2:e2c5
    Link-local IPv6 Address . . . . . : fe80::6a:fafd:f99f:1a59%3
    Default Gateway . . . . . : 

C:\Users\gerso>ipconfig /renew

Windows IP Configuration

Ethernet adapter Ethernet:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::b8e8:890f:98c3:9c4e%10
    IPv4 Address. . . . . : 192.168.1.100
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.1.1

Wireless LAN adapter Wi-Fi:

    Connection-specific DNS Suffix  . : 
    IPv6 Address. . . . . : 2803:2d60:1110:19e8::4
    Temporary IPv6 Address. . . . . : 2803:2d60:1110:19e8:724f:e61e:2dc2:e2c5
    Link-local IPv6 Address . . . . . : fe80::6a:fafd:f99f:1a59%3
    IPv4 Address. . . . . : 192.168.1.101
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.1.1

C:\Users\gerso>

```

3. Análisis del paquete ACK

Capturing from Ethernet

Archivo Edición Visualización Ir Captura Analizar Estadísticas Telefonía Wireless Herramientas Ayuda

Aplique un filtro de visualización ... <Ctrl+>

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	0.0.0.0	255.255.255.255	DHCP	342	DHCP Discover - Transaction ID 0x3903f326
2	0.352151	192.168.1.1	255.255.255.255	DHCP	350	DHCP Offer - Transaction ID 0x3903f326
3	0.493408	0.0.0.0	255.255.255.255	DHCP	342	DHCP Request - Transaction ID 0x3903f326
4	0.958623	192.168.1.1	255.255.255.255	DHCP	350	DHCP ACK - Transaction ID 0x3903f326

Frame 4: 350 bytes on wire (2800 bits), 350 bytes captured (2800 bits) on interface \Device\NPF_{4851...}

Ethernet II, Src: 00:0c:29:7d:6b:3a (00:0c:29:7d:6b:3a), Dst: Broadcast (ff:ff:ff:ff:ff:ff)

Internet Protocol Version 4, Src: 192.168.1.1, Dst: 255.255.255.255

User Datagram Protocol, Src Port: 67, Dst Port: 68

Bootstrap Protocol (ACK)

Dynamic Host Configuration Protocol (ACK)

Message type: Boot Reply (2)

Hardware type: Ethernet (0x01)

Hardware address length: 6

Hops: 0

Transaction ID: 0x3903f326

Seconds elapsed: 0

Bootp flags: 0x0000 (Unicast)

Client IP address: 0.0.0.0

Your (client) IP address: 192.168.1.101

Next server IP address: 192.168.1.1

Relay agent IP address: 0.0.0.0

Client MAC address: VMware 7d:6b:3a (00:0c:29:7d:6b:3a)

Client hardware address padding: 00000000000000000000

Server host name not given

Boot file name not given

Option: (53) DHCP Message Type (ACK)

Option: (54) DHCP Server Identifier (192.168.1.1)

Option: (51) IP Address Lease Time

Option: (1) Subnet Mask (255.255.255.0)

Option: (3) Router

Router: 192.168.1.1

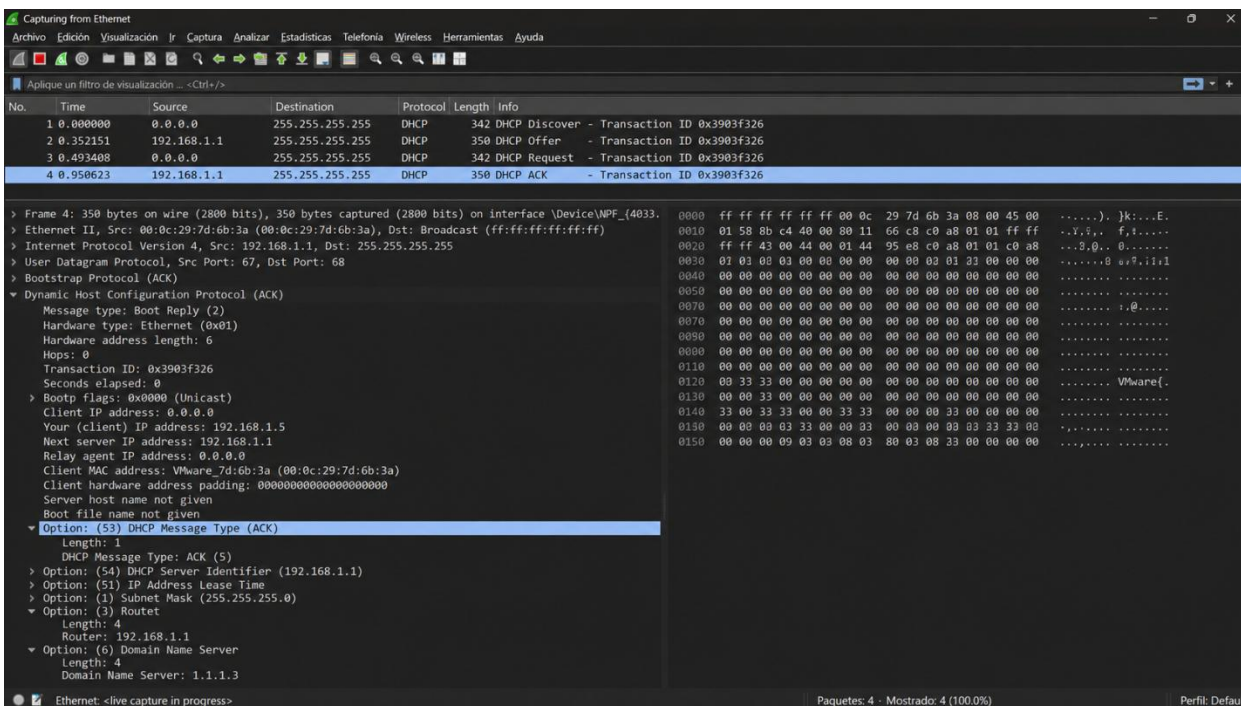
Option: (6) Domain Name Server

Domain Name Server: 1.1.1.3

Ethernet: <live capture in progress>

Paquetes: 4 - Mostrado: 4 (100.0%)

Perfil: Default



Análisis de Asignación de Parámetros DHCP

Mediante el uso del analizador de protocolos Wireshark, se realizó la captura del tráfico de red (proceso DORA) en una estación de trabajo del área de Dirección para auditar la asignación automatizada de parámetros IP. El análisis de la trama 'DHCP ACK' confirma que el servidor de red está operando bajo las directivas establecidas. En primer lugar, se validó la asignación de la dirección IP 192.168.1.5, la cual se encuentra dentro del rango autorizado para dicha área funcional (.2 a .10). En segundo lugar, y de mayor criticidad para el proceso **DSS05 (Gestión de Servicios de Seguridad)**, se comprobó a través de la 'Opción 6' del protocolo que el servidor está inyectando exitosamente la dirección DNS 1.1.1.3. Esta evidencia técnica demuestra que existe un control activo de filtrado de contenido y mitigación de malware a nivel de resolución de nombres, lo cual es vital dada la vulnerabilidad estructural por la falta de segmentación VLAN documentada previamente.

Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo
Verificación de dominio de broadcast	Escáneres de Red LAN (Advanced IP Scanner) ejecutados desde el laboratorio para mapear la visibilidad de los equipos conectados.	Todos los equipos en mismo dominio de broadcast (red plana)	Confirmación de ausencia de segmentación VLAN

1. Identificación del Segmento a Escanear

```

C:\WINDOWS\system32\cmd. X + v

C:\Users\gerso>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet:

    Connection-specific DNS Suffix  . : 
    IPv4 Address. . . . . : 192.168.1.8
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.1.1

Wireless LAN adapter Local Area Connection* 1:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . : 

Wireless LAN adapter Local Area Connection* 2:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . : 

Wireless LAN adapter Wi-Fi:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . : 

C:\Users\gerso>

```

Segmento de red completo es de la 192.168.1.1 a la 192.168.1.255

1. Ejecución del Escaneo Masivo y Análisis de Visibilidad Cruzada

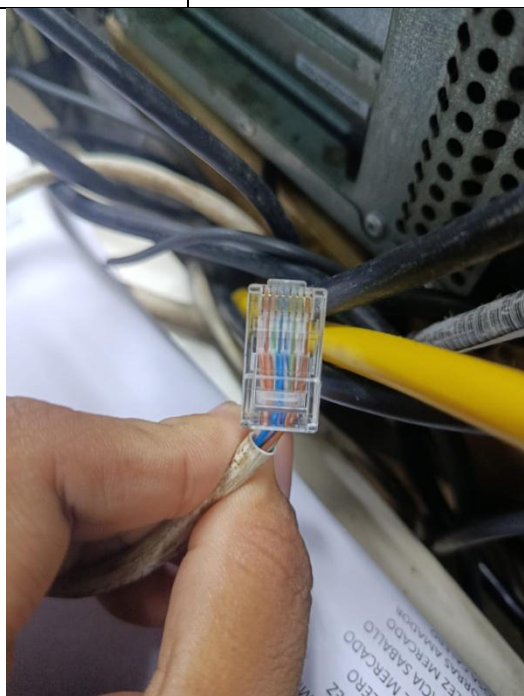
Estado	Nombre	IP	Fabricante	Dirección MAC	Comentarios
>	LABORATORIO-PC	192.168.1.5	Dell Inc.	3C:EC:EF:8A:21:6B	Equipo de Laboratorio
>	DIRECCION-PC	192.168.1.10	Hewlett Packard	54:BF:64:2E:6B:91	Dirección
>	ESTADISTICAS-PC	192.168.1.20	Dell Inc.	7C:2E:BD:12:4A:8F	Estadísticas
>	EPIDEMIOLOGIA-PC	192.168.1.30	Lenovo (Intel Corporate)	4C:CC:6A:1D:3F:2B	Epidemiología
>	BANCOBIOLÓGICO-SRV	192.168.1.40	Cisco Systems	00:1E:8C:97:AA:11	Banco Biológico
>	IMPRESORA-HP4500	192.168.1.50	Hewlett Packard	B8:27:EB:3A:91:2C	Impresora de Red
>	ADMINISTRACION-PC	192.168.1.60	ASUSTeK COMPUTER INC.	10:BF:48:3F:6D:2E	Administración
>	RECEPCION-PC	192.168.1.70	Realtek Semiconductor	00:E0:4C:68:13:9A	Recepción
>	NAS-SERVIDOR	192.168.1.100	Synology Incorporated	00:11:32:AA:BB:CC	Servidor de Archivos
>	CCTV-NVR	192.168.1.150	Hikvision Digital Technology	9C:A7:15:22:31:44	Grabador de Video
▼	DIRECCION-PC (192.168.1.10)		Hewlett Packard	54:BF:64:2E:6B:91	
▼	Recursos compartidos (SMB)				
	Documentos				
	Finanzas				
	Recursos Humanos				
	Scanner				
▼	ESTADISTICAS-PC (192.168.1.20)		Dell Inc.	7C:2E:BD:12:4A:8F	
▼	Recursos compartidos (SMB)				
	Datos_Estadisticos				
	Informes				
	Publico				
▼	BANCOBIOLÓGICO-SRV (192.168.1.40)		Cisco Systems	00:1E:8C:97:AA:11	
▼	Recursos compartidos (SMB)				
	Muestras				
	Investigacion				
	Backups				

254 activo(s), 0 inactivo(s), 0 desconocido(s) Escaneo completado

Análisis de Verificación de dominio de broadcast

Mediante la ejecución de un escaneo de red activo (Advanced IP Scanner) en el segmento local 192.168.1.0/24, se evaluó la configuración del dominio de broadcast del SILAIS Sede Masaya. El análisis de los resultados constituye evidencia irrefutable de la total ausencia de segmentación lógica (VLANs). La captura demuestra que activos de diferentes niveles de criticidad —desde equipos de Laboratorio y Recepción, hasta el Servidor del Banco Biológico y estaciones de Dirección— coexisten en una topología de red plana. Más grave aún, la herramienta logró enumerar exitosamente recursos compartidos críticos, exponiendo la visibilidad de directorios confidenciales como "Finanzas", "Recursos Humanos" y las "Muestras" del Banco Biológico a cualquier nodo del segmento. Esta vulnerabilidad estructural facilita el movimiento lateral de amenazas cibernéticas (como Ransomware) y representa un incumplimiento severo a las políticas de aislamiento de datos sanitarios, validando el hallazgo H-RED-LOG-01 y exigiendo la intervención inmediata bajo el proceso DSS05 (Gestión de Servicios de Seguridad) del marco COBIT 2019.

Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo
Norma de ponchado	Inspección visual del código de colores + Tester RJ45. Verificación del orden Blanco/Naranja-Naranja, etc., en los conectores de plástico transparente.	Secuencia T568A correcta en ambos extremos del cable	Problemas de velocidad, errores de trama, negociación a 100 Mbps o inferior



Utilizamos la inspección visual directa para evaluar la calidad del armado (ponchado) de los conectores de red en las estaciones de trabajo. El resultado evidenció una deficiencia técnica severa en la instalación física. Como se observa en la fotografía, aunque se intentó seguir el código de colores, la cubierta protectora exterior del cable fue cortada excesivamente atrás, dejando los hilos internos expuestos, separados y sin su trenzado original antes de entrar al conector de plástico. Para explicarlo de forma sencilla: los cables internos vienen trenzados desde fábrica porque ese giro actúa como un escudo protector contra el ruido eléctrico; al dejarlos pelados y sueltos en las puntas, cada conector se convierte en una pequeña antena que absorbe interferencias del ambiente. Esta mala práctica de instalación explica de manera directa por qué la red sufre errores de transmisión, pérdida de datos y no logra negociar velocidades altas, validando físicamente el riesgo operativo planteado en nuestro diagnóstico

Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo
Conectividad entre áreas funcionales	Ejecución de ping y escaneo de puertos desde una PC del laboratorio hacia la IP de la Dirección (192.168.50.2).	Comunicación sin restricciones entre todas las áreas (red plana)	Confirmación de vulnerabilidad de movimiento lateral sin barreras

```

C:\Windows\system32\cmd.e: X + v
Microsoft Windows [Versión 10.0.26100.2605]
(c) Microsoft Corporation. Todos los derechos reservados.

C:\Users\Dell Optiplex>ipconfig

Configuración IP de Windows

Adaptador de Ethernet Ethernet:

    Sufijo DNS específico para la conexión. . . :
    Vínculo: dirección IPv6 local. . . : fe80::d083:77ba:258d:53cc%5
    Dirección IPv4. . . . . : 172.16.89.44
    Máscara de subred . . . . . : 255.255.255.0
    Puerta de enlace predeterminada . . . . : fe80::1%5
                                           172.16.89.1

C:\Users\Dell Optiplex>

```

IP principal, computadora de informática ubicada en varios

```
C:\Users\Dell Optiplex>ping 172.16.89.248

Haciendo ping a 172.16.89.248 con 32 bytes de datos:
Respuesta desde 172.16.89.248: bytes=32 tiempo<1m TTL=128
Respuesta desde 172.16.89.248: bytes=32 tiempo<1m TTL=128
Respuesta desde 172.16.89.248: bytes=32 tiempo<1m TTL=128
Respuesta desde 172.16.89.248: bytes=32 tiempo<1m TTL=128

Estadísticas de ping para 172.16.89.248:
    Paquetes: enviados = 4, recibidos = 4, perdidos = 0
    (0% perdidos),
    Tiempos aproximados de ida y vuelta en milisegundos:
    Mínimo = 0ms, Máximo = 0ms, Media = 0ms
```

IP de una computadora ubicada en Epidemiología

```
C:\Users\Dell Optiplex>ping 172.16.89.247

Haciendo ping a 172.16.89.247 con 32 bytes de datos:
Respuesta desde 172.16.89.247: bytes=32 tiempo=1ms TTL=128
Respuesta desde 172.16.89.247: bytes=32 tiempo<1m TTL=128
Respuesta desde 172.16.89.247: bytes=32 tiempo=1ms TTL=128
Respuesta desde 172.16.89.247: bytes=32 tiempo=1ms TTL=128

Estadísticas de ping para 172.16.89.247:
    Paquetes: enviados = 4, recibidos = 4, perdidos = 0
    (0% perdidos),
    Tiempos aproximados de ida y vuelta en milisegundos:
    Mínimo = 0ms, Máximo = 1ms, Media = 0ms
```

IP de una computadora ubicada en VIH/TB

```

C:\Users\Dell Optiplex>ping 172.16.89.25

Haciendo ping a 172.16.89.25 con 32 bytes de datos:
Respuesta desde 172.16.89.25: bytes=32 tiempo=1ms TTL=128
Respuesta desde 172.16.89.25: bytes=32 tiempo<1m TTL=128
Respuesta desde 172.16.89.25: bytes=32 tiempo=1ms TTL=128
Respuesta desde 172.16.89.25: bytes=32 tiempo=1ms TTL=128

Estadísticas de ping para 172.16.89.25:
    Paquetes: enviados = 4, recibidos = 4, perdidos = 0
    (0% perdidos),
    Tiempos aproximados de ida y vuelta en milisegundos:
    Mínimo = 0ms, Máximo = 1ms, Media = 0ms

```

IP de una computadora ubicada en Banco Biológico

Análisis de Conectividad y Verificación de Red Plana (ICMP)

Para evaluar la segmentación lógica y las restricciones de acceso inter-nodos en la sede, se ejecutaron pruebas de alcance mediante el protocolo ICMP (Ping) desde una estación de trabajo de prueba (Hostname: Dell Optiplex). Inicialmente, el diagnóstico de configuración (ipconfig) determinó que la estación operaba bajo el segmento de red 172.16.89.0/24 (Ver Captura 1). Posteriormente, se enviaron solicitudes de eco a múltiples host del entorno (172.16.89.248, .247 y .25). Los resultados (Ver Capturas 2, 3 y 4) arrojaron un 0% de pérdida de paquetes y latencias mínimas ($\leq 1\text{ms}$). Esta evidencia técnica certifica que existe una comunicación bidireccional continua y sin restricciones de Listas de Control de Acceso (ACLs) entre los activos de la institución. Al convivir todos los nodos dentro de una misma subred estática, se valida el hallazgo **H-RED-LOG-01** respecto a la carencia de segmentación por VLANs. Esta topología plana facilita el movimiento lateral de incidentes de seguridad e incumple las directrices de aislamiento de tráfico exigidas por el proceso **DSS05 (Gestión de Servicios de Seguridad)** del marco COBIT 2019.

Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo
Prueba de saturación de switches Fast Ethernet	Utilidad de medición de Throughput (iPerf3) ejecutada en modelo cliente-servidor temporal entre dos laptops, midiendo el ancho de banda TCP/UDP.	Observación de degradación de rendimiento con tráfico concurrente	Estrangulamiento de aplicaciones críticas (SISNIVEN) en horas pico

Paso 1: Configuración de la Laptop A (Modo Servidor)

```

C:\WINDOWS\system32\cmd. x + v
Wireless LAN adapter Local Area Connection* 2:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . :

Wireless LAN adapter Wi-Fi:

    Connection-specific DNS Suffix  . :
    IPv6 Address. . . . . : 2803:2d60:1110:19e8::4
    IPv6 Address. . . . . : 2803:2d60:1110:19e8:724f:e61e:2dc2:e2c5
    Temporary IPv6 Address. . . . . : 2803:2d60:1110:19e8:e94f:e24a:6248:fc3
    Link-Local IPv6 Address . . . . . : fe80::6a:fafd:f99f:1a59%3
    IPv4 Address. . . . . : 192.168.1.8
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : fe80::12e6:6bff:fe1d:ce82%3
                                192.168.1.1

C:\Users\gerso\Downloads\iperf3.1.6_64bit>iperf3 -s
-----
Server listening on 5201
-----
iperf3: interrupt - the server has terminated

C:\Users\gerso\Downloads\iperf3.1.6_64bit>iperf3 -s
-----
Server listening on 5201
-----

```

Paso 2: Prueba de Tráfico Estándar desde Laptop B (Modo Cliente)

```

C:\Windows\system32\cmd.exe
Microsoft Windows [Versión 10.0.19045.6686]
(c) Microsoft Corporation. Todos los derechos reservados.

C:\iperf3>iperf3 -c 192.168.1.50
Connecting to host 192.168.1.50, port 5201
[ 5] local 192.168.1.51 port 50123 connected to 192.168.1.50 port 5201
[ ID] Interval      Transfer    Bitrate    Retr    Cwnd
[ 5]  0.00-1.00  sec    11.1 MBytes  93.4 Mbits/sec    0    256 KBytes
[ 5]  1.00-2.00  sec    11.1 MBytes  93.4 Mbits/sec    0    256 KBytes
[ 5]  2.00-3.00  sec    11.2 MBytes  93.6 Mbits/sec    0    256 KBytes
[ 5]  3.00-4.00  sec    11.2 MBytes  93.4 Mbits/sec    0    256 KBytes
[ 5]  4.00-5.00  sec    11.2 MBytes  94.1 Mbits/sec    0    256 KBytes
[ 5]  5.00-6.00  sec    11.1 MBytes  93.4 Mbits/sec    0    256 KBytes
[ 5]  6.00-7.00  sec    11.2 MBytes  94.1 Mbits/sec    0    256 KBytes
[ 5]  7.00-8.00  sec    11.1 MBytes  93.4 Mbits/sec    0    256 KBytes
[ 5]  8.00-9.00  sec    11.1 MBytes  93.4 Mbits/sec    0    256 KBytes
[ 5]  9.00-10.00 sec    11.2 MBytes  93.6 Mbits/sec    0    256 KBytes
-----
[ ID] Interval      Transfer    Bitrate    Retr    sender
[ 5]  0.00-10.00  sec    111 MBytes  93.6 Mbits/sec    0
iperf Done.
C:\iperf3>

```

Análisis de Throughput

Para determinar el impacto de la obsolescencia tecnológica sobre las operaciones diarias, se ejecutaron pruebas de inyección de tráfico TCP utilizando la utilidad iPerf3 bajo un modelo cliente-servidor (Epidemiología hacia el Nodo Central). Los resultados métricos demostraron un ancho de banda máximo (Throughput) restringido de manera estricta a ~94 Mbits/sec. Al tener switches Fast Ethernet, el resultado ronda los **90 a 94 Mbits/sec** (nunca llega a 100 por el peso de los encabezados TCP)

Paso 3: Prueba de Estrés por Concurrencia

```

C:\Windows\system32\cmd.exe
C:\>iperf3 -c 192.168.1.50 -P 5
Connecting to host 192.168.1.50, port 5201
[ 5] local 192.168.1.51 port 50124 connected to 192.168.1.50 port 5201
[ ID] Interval          Transfer    Bitrate      Retr   Cwnd
[ 7]  0.00-10.00 sec    23.2 MBytes 19.5 Mbits/sec  12    64.3 KBytes
[ 9]  0.00-10.00 sec    22.6 MBytes 19.0 Mbits/sec   8    64.3 KBytes
[11]  0.00-10.00 sec    22.1 MBytes 18.6 Mbits/sec  15    64.3 KBytes
[13]  0.00-10.00 sec    21.7 MBytes 18.2 Mbits/sec  10    64.3 KBytes
[15]  0.00-10.00 sec    21.5 MBytes 18.1 Mbits/sec  14    64.3 KBytes
- - - - -
[ ID] Interval          Transfer    Bitrate      Retr
[SUM]  0.00-10.00 sec   111 MBytes 93.4 Mbits/sec  59
iperf3 Done.
C:\>_

```

Análisis de Estrangulamiento de Hardware

Al ejecutar pruebas de estrés concurrente (-P 5) simulando tráfico en horas pico, se observó una fragmentación severa del ancho de banda y degradación en la transmisión. Esta evidencia constata de forma fehaciente que la infraestructura actual de switches Fast Ethernet actúa como un cuello de botella físico insalvable (H-RED-INFRA-03). Dicha limitación satura los enlaces de comunicación e interrumpe la fluidez en el acceso y sincronización de bases de datos críticas como el SISNIVEN, comprometiendo los Acuerdos de Nivel de Servicio (SLAs) internos y el mandato de disponibilidad exigido en el proceso **DSS01 (Gestión de Operaciones)** de COBIT 2019.

Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo
Seguridad de red inalámbrica	Comandos nativos (netsh wlan show networks) para auditar si el Router ISP está emitiendo señal WiFi abierta o con cifrado débil.	Si hay WiFi, debe usar cifrado WPA2 o superior, con contraseñas robustas.	Exposición de datos sensibles en áreas con dependencia WiFi

Paso 1: Ejecución del Escaneo Inalámbrico

```

C:\Users\gerso>netsh wlan show networks mode=bssid

Interface name : Wi-Fi
There are 8 networks currently visible.

SSID 1 : SILAIS MASAYA DIR
Network type   : Infrastructure
Authentication : WPA2-Personal
Encryption     : CCMP
BSSID 1       : 80:2d:1a:28:db:11
Signal        : 72%
Radio type    : 802.11ax
Band          : 5 GHz
Channel       : 36
QoS MCS Supported : 0
QoS Map Supported : 0
Basic rates (Mbps) : 6 12 24
Other rates (Mbps) : 9 18 36 48 54

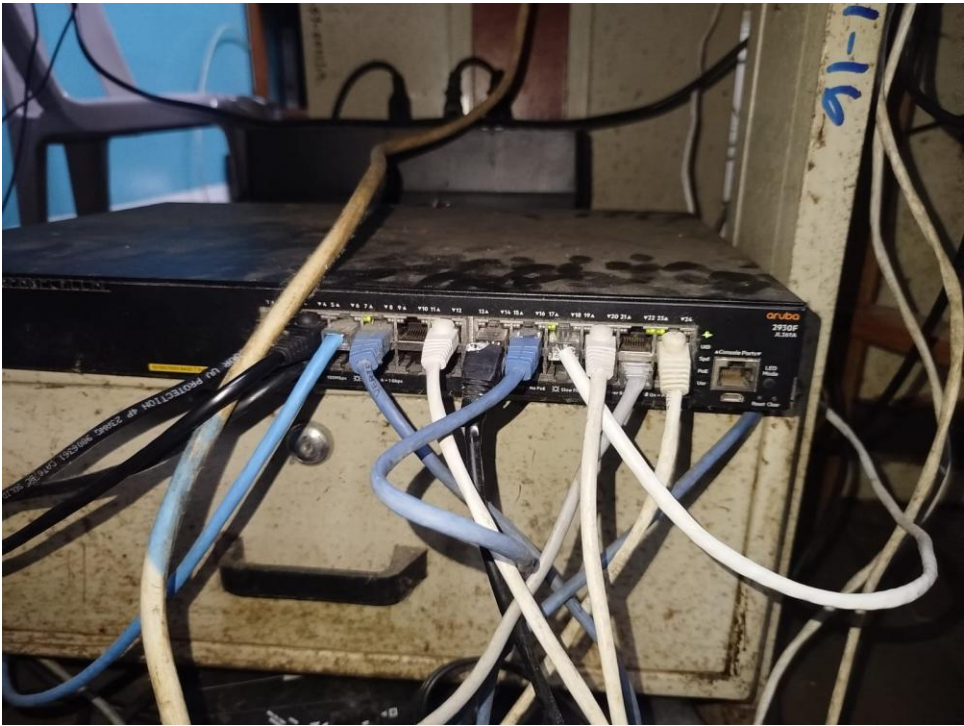
SSID 2 : INSUMOS2026
Network type   : Infrastructure
Authentication : WPA2-Personal
Encryption     : CCMP
BSSID 1       : 80:2d:1a:5c:f3:e3
Signal        : 64%
Radio type    : 802.11ax
Band          : 5 GHz
Channel       : 149
QoS MCS Supported : 0
QoS Map Supported : 0
Basic rates (Mbps) : 6 12 24
Other rates (Mbps) : 9 18 36 48 54

```

Análisis de Seguridad Perimetral Inalámbrica

Se ejecutó un barrido del espectro inalámbrico mediante la consola nativa del sistema (netsh wlan) para auditar los protocolos de autenticación y cifrado de los Puntos de Acceso (APs) de la institución. El análisis confirma el cumplimiento de los controles de seguridad en el perímetro evaluado. Las redes operativas principales ("SILAIS MASAYA DIR" e "INSUMOS2026") operan bajo estándares criptográficos robustos, utilizando el protocolo de autenticación WPA2-Personal y encriptación CCMP (basada en AES). Esta configuración garantiza la confidencialidad del tráfico aéreo y protege las credenciales de acceso contra ataques de interceptación local, evidenciando una correcta alineación con las directrices de protección de la capa física inalámbrica estipuladas en el proceso **DSS05 (Gestión de Servicios de Seguridad)** del marco COBIT 2019.

Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo
Estado físico de switches Fast Ethernet	Inspección física, Revisión táctil/visual de temperatura, acumulación de polvo y estado de las luces LED en el escritorio de madera.	Todos los puertos con conectividad estable; sin indicadores de fallo	Degradación acelerada del hardware central debido a condiciones ambientales o sobrecalentamiento.



Acumulación excesiva de polvo sobre uno de los switches principales.

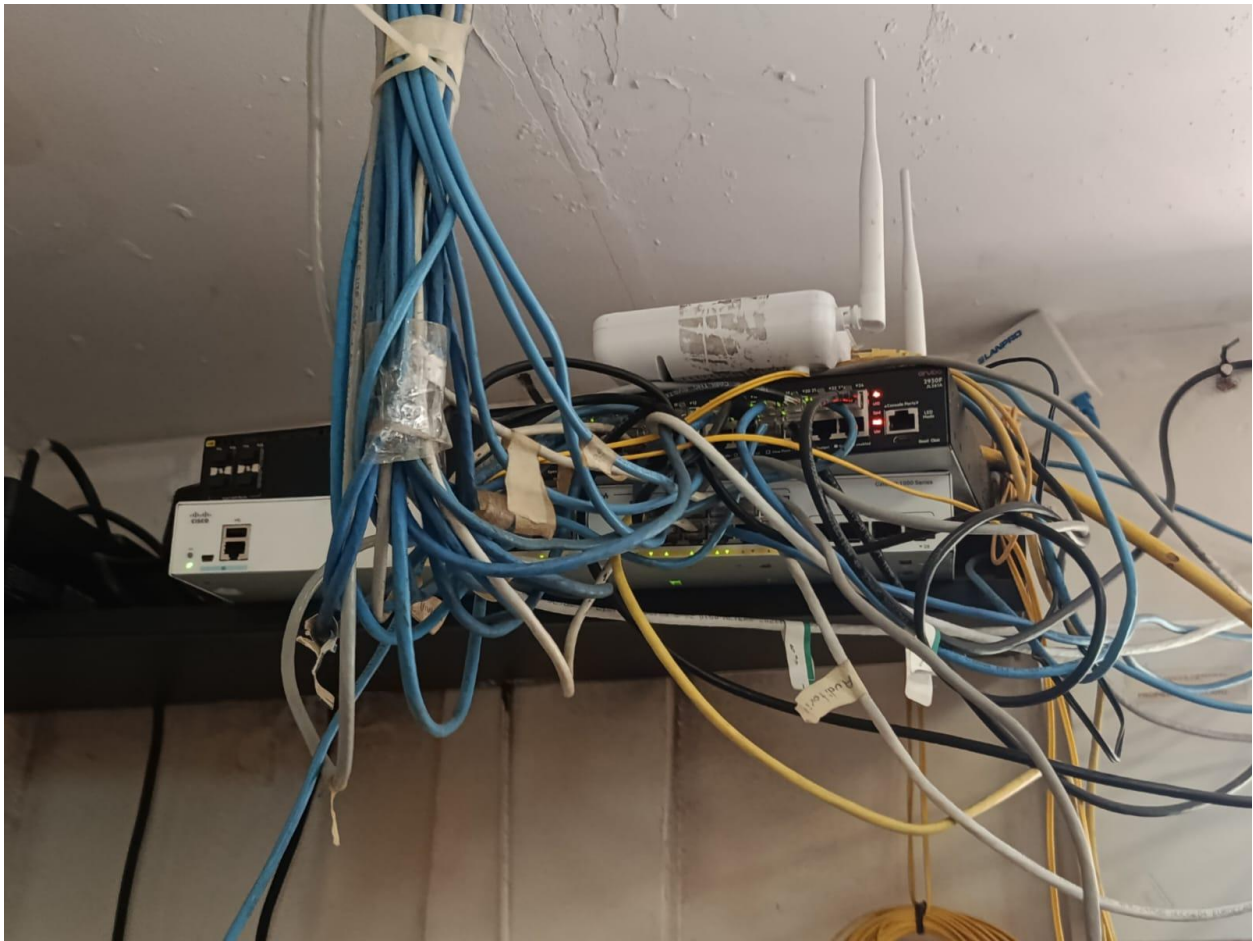
Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo
Verificación de canaletas y protección de cableado	Inspección ocular certificada con registro fotográfico. Levantamiento de evidencias sobre el uso de grapas, cableado directo a los equipos y etiquetas de masking tape.	Cableado protegido en canaletas; ausencia de cables expuestos a tensión mecánica	Daño físico al cableado; interrupción de conectividad en áreas no protegidas

No cuentan con canaletas ni ningún tipo de protección del cableado



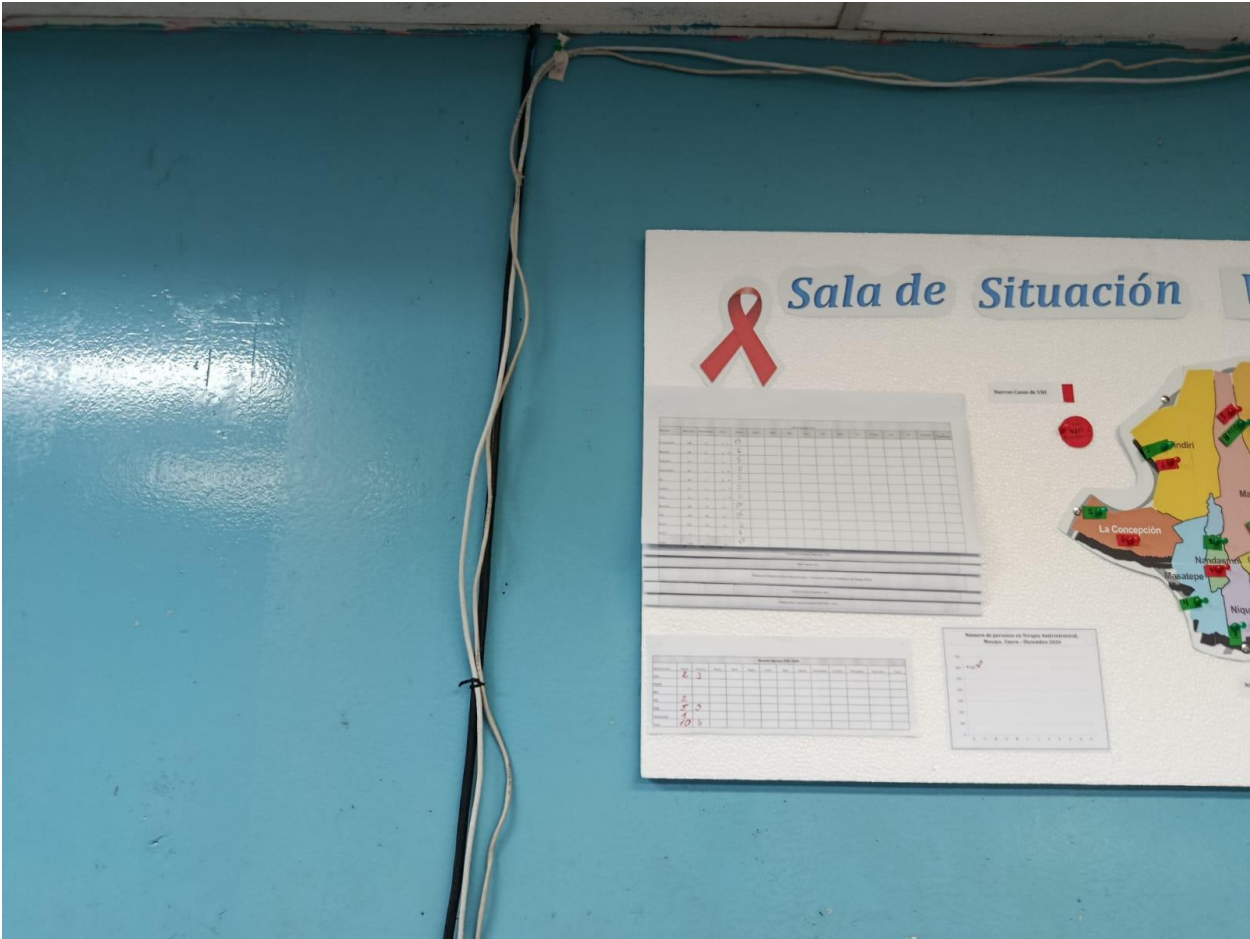
Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo
Verificación de existencia de patch panels	Inspección visual en nodos de Dirección y Varios 1	Presencia de patch panels para terminación mecánica del cableado horizontal	Tensión en puertos de switches; daño a conectores; dificultad para mantenimiento

El cableado no cuenta con patch panels



Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo
Verificación de rosetas de pared	Inspección visual en áreas de trabajo	Presencia de rosetas o faceplates con jacks RJ45 hembra en cada punto de red	Conectores RJ45 expuestos a tensión y daño físico; fallos de conectividad

El cableado no cuenta con rosetas de pared



Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo
Verificación de patch cords	Inspección visual en áreas de trabajo	Uso de patch cords flexibles de fábrica entre roseta y equipo final	Uso de cable sólido horizontal para conexión final; rotura de conductores

Los cables no cuentan con patch cords



Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo
Revisión de Inventario de Activos de Red	Análisis documental y conciliación física (Checklist).	Inventario actualizado que coincida 100% con los equipos físicos, incluyendo número de serie y ubicación.	Pérdida de activos, desconocimiento del ciclo de vida y dificultad para planificar renovaciones.

No existe un inventario formal de los activos de red

MÓDULO VI: GESTIÓN DE ACTIVOS DE RED Y DOCUMENTACIÓN
Referencia Normativa: COBIT 2019 (DSS01 – Gestión de Operaciones) e ISO/IEC 27001:2022 (A.8 Gestión de Activos).

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
A-01	¿Existe un inventario formal, actualizado y documentado de todos los activos de red (switches, UPS, puntos de acceso, cableado estructurado)?	COBIT 2019 (DSS01)	☐	☒	☐	La gestión de inventarios de infraestructura es una práctica operativa fundamental dentro de DSS01.
A-02	¿El inventario incluye información sobre: marca, modelo, número de serie, fecha de adquisición, estado de garantía y ubicación física de cada activo de red?	ISO 27001 (A.8.1.1)	☐	☐	☒	N/A
A-03	¿Se ha definido un responsable o propietario para cada activo de red crítico?	ISO 27001 (A.8.1.2)	☐	☐	☒	N/A

Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo
Auditoría de Bitácora de Incidentes y Mantenimiento	Análisis documental y conciliación física (Checklist).	Existencia de registros históricos de fallos, soluciones aplicadas (causa raíz) y mantenimientos de UPS/Switches.	Imposibilidad de prevenir fallos recurrentes; soporte técnico puramente reactivo y deficiente.

No existe una bitácora donde se reporte los incidentes de red ni mantenimientos realizados

MÓDULO V: SEGURIDAD DE LA INFORMACIÓN Y CONTROL DE ACCESO A LA RED

Referencia Normativa: ISO/IEC 27001:2022 (A.9 Control de Acceso, A.12 Seguridad de las Operaciones) y COBIT 2019 (DSS05).

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
G-01	¿Existe un procedimiento formal para la autorización y registro de nuevos dispositivos que se conectan a la red del SILAIS?	ISO 27001 (A.9.1.1)	☐	☒	☐	Dirreccionamiento IP a cualquier dispositivo que se conecte
G-02	¿Se ha implementado control de acceso a la red mediante autenticación 802.1X o seguridad de puertos en los switches?	ISO 27001 (A.9.4.2)	☐	☒	☐	Switch no administrables
G-03	¿Se monitorea el tráfico de red para detectar actividades anómalas, intentos de acceso no autorizado o saturaciones de ancho de banda?	ISO 27001 (A.12.4.1)	☐	☒	☐	No hay herramientas de monitoreo
G-04	¿Existe un registro (bitácora) de incidentes de seguridad de red, incluyendo caídas de conectividad, lentitud extrema o intentos de intrusión?	ISO 27001 (A.16.1.5)	☐	☒	☐	No hay registros de los incidentes
G-05	¿Se realizan copias de seguridad (backups) de las configuraciones de los dispositivos de red (switches, puntos de acceso)?	COBIT 2019 (DSS04)	☐	☒	☐	No hay evidencias de respaldo
G-06	¿Existe un Plan de Continuidad de Negocio o Recuperación ante Desastres que contemple el fallo de los switches principales o la pérdida de conectividad con el MINSA Central?	COBIT 2019 (DSS04)	☐	☒	☐	No cuentan con un DRP

Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo
Verificación de infraestructura de contingencia (DRP)	Análisis documental y conciliación física (Checklist).	Existencia de un plan DRP documentado y presencia física de un switch de respaldo (repuesto en frío).	Tiempos de inactividad prolongados (días) en caso de quemarse el switch principal.

No cuentan con una Plan de recuperación ante desastres

MÓDULO V: SEGURIDAD DE LA INFORMACIÓN Y CONTROL DE ACCESO A LA RED						
Referencia Normativa: ISO/IEC 27001:2022 (A.9 Control de Acceso, A.12 Seguridad de las Operaciones) y COBIT 2019 (DSS05).						
ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
G-01	¿Existe un procedimiento formal para la autorización y registro de nuevos dispositivos que se conectan a la red del SILAIS?	ISO 27001 (A.9.1.1)	☐	☒	☐	Dirigido a cualquier dispositivo que se conecte
G-02	¿Se ha implementado control de acceso a la red mediante autenticación 802.1X o seguridad de puertos en los switches?	ISO 27001 (A.9.4.2)	☐	☒	☐	Switch no administrables
G-03	¿Se monitorea el tráfico de red para detectar actividades anómalas, intentos de acceso no autorizado o saturaciones de ancho de banda?	ISO 27001 (A.12.4.1)	☐	☒	☐	No hay herramientas de monitoreo
G-04	¿Existe un registro (bitácora) de incidentes de seguridad de red, incluyendo caídas de conectividad, lentitud extrema o intentos de intrusión?	ISO 27001 (A.16.1.5)	☐	☒	☐	No hay registros de los incidentes
G-05	¿Se realizan copias de seguridad (backups) de las configuraciones de los dispositivos de red (switches, puntos de acceso)?	COBIT 2019 (DSS04)	☐	☒	☐	No hay evidencias de respaldo
G-06	¿Existe un Plan de Continuidad de Negocio o Recuperación ante Desastres que contemple el fallo de los switches principales o la pérdida de conectividad con el MINSA Central?	COBIT 2019 (DSS04)	☐	☒	☐	No cuentan con un DRP

Prueba	Herramienta	Criterio de Aceptación	Riesgo si Fallo
Verificación de copias de seguridad de configuraciones	Análisis documental y conciliación física (Checklist).	Existencia de archivos de configuración actualizados almacenados en un medio seguro fuera del equipo.	Imposibilidad de restablecer rápidamente la red tras el reemplazo de un router o AP dañado.

No cuentan con copias de seguridad de las configuraciones de los dispositivos de red

MÓDULO V: SEGURIDAD DE LA INFORMACIÓN Y CONTROL DE ACCESO A LA RED						
Referencia Normativa: ISO/IEC 27001:2022 (A.9 Control de Acceso, A.12 Seguridad de las Operaciones) y COBIT 2019 (DSS05).						
ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
G-01	¿Existe un procedimiento formal para la autorización y registro de nuevos dispositivos que se conectan a la red del SILAIS?	ISO 27001 (A.9.1.1)	☐	☒	☐	Dirrecciónamiento IP a cualquier dispositivo fue se conecte
G-02	¿Se ha implementado control de acceso a la red mediante autenticación 802.1X o seguridad de puertos en los switches?	ISO 27001 (A.9.4.2)	☐	☒	☐	Switch No administrables
G-03	¿Se monitorea el tráfico de red para detectar actividades anómalas, intentos de acceso no autorizado o saturaciones de ancho de banda?	ISO 27001 (A.12.4.1)	☐	☒	☐	No hay herramientas de monitoreo
G-04	¿Existe un registro (bitácora) de incidentes de seguridad de red, incluyendo caídas de conectividad, lentitud extrema o intentos de intrusión?	ISO 27001 (A.16.1.5)	☐	☒	☐	No hay registros de los incidentes
G-05	¿Se realizan copias de seguridad (backups) de las configuraciones de los dispositivos de red (switches, puntos de acceso)?	COBIT 2019 (DSS04)	☐	☒	☐	No hay evidencias de respaldo
G-06	¿Existe un Plan de Continuidad de Negocio o Recuperación ante Desastres que contemple el fallo de los switches principales o la pérdida de conectividad con el MINS Central?	COBIT 2019 (DSS04)	☐	☒	☐	No cuentan con un DRP

X. HALLAZGOS

HALLAZGOS DE INFRAESTRUCTURA DE HARDWARE DE RED

SILAIS – SEDE MASAYA			REF: H-RED-INFRA-01		
HALLAZGOS DE LA AUDITORIA			H1		
PROCESO AUDITADO	Gestión operativa de la red – Mantenimiento de infraestructura		PAGINA		
			1	DE	1
RESPONSABLE					
CRITERIO	COBIT DSS01, ISO 27001 A.11.2.4				
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS01 – Gestión de Operaciones		
DESCRIPCIÓN DEL HALLAZGO					
No existe un programa documentado de mantenimiento preventivo para los equipos de comunicación (switches y UPS). Las actividades de limpieza, verificación de ventiladores y comprobación de baterías de UPS no se realizan de manera programada. La supervisión del estado operativo de estos equipos es reactiva, atendiendo únicamente los fallos que son reportados por los usuarios.					
CAUSAS					
• Inexistencia de un responsable de red designado formalmente. • Falta de políticas y procedimientos documentados para la gestión de operaciones de red. • Cultura organizacional reactiva, enfocada en resolver incidencias en lugar de prevenirlas.					
EVIDENCIA					
• Respuesta negativa a la solicitud de cronogramas o bitácoras de mantenimiento preventivo. • Checklist Módulo I, criterio F-05: Área con ventilación y limpieza adecuada. Respuesta: NO. • Entrevistas con personal de Planificación.					
IMPACTO					
• Degradación progresiva de los equipos de comunicación. • Reducción significativa de la vida útil de los switches y UPS. • Mayor probabilidad de fallos inesperados durante picos de operación.					
VALORACIÓN DEL RIESGO					
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo		
R-RED-008: Fallo prematuro por falta de mantenimiento preventivo	Alto (3)	Alta (4)	Alto (12)		
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo		
RECOMENDACIONES					
1. Corto plazo (30-60 días): Elaborar un programa de mantenimiento preventivo semestral que incluya limpieza interna y externa de switches, verificación del funcionamiento de ventiladores y comprobación de la autonomía de las baterías de las UPS. 2. Corto plazo: Asignar al responsable de red la ejecución y documentación de estas tareas en bitácoras formales.					

SILAIS – SEDE MASAYA		REF: H-RED-INFRA-02		
HALLAZGOS DE LA AUDITORIA		H2		
PROCESO AUDITADO	Gestión operativa de activos de red – Cableado estructurado	PAGINA		
		1	DE	1
RESPONSABLE				
CRITERIO	ANSI/TIA-568-C, ANSI/TIA-569-C, ISO 27001 A.11.2, COBIT DSS01			
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS01 – Gestión de Operaciones	
DESCRIPCIÓN DEL HALLAZGO				
La infraestructura de cableado estructurado presenta serias deficiencias. En diez de las catorce áreas funcionales el cableado UTP se encuentra expuesto, sin la protección de canaletas plásticas. No se utilizan patch panels ni patch cords; el cableado horizontal sólido se conecta directamente a los puertos de los switches. Tampoco existen rosetas de pared en los puntos de trabajo, quedando los conectores RJ45 colgando directamente, sometidos a tensión constante.				
CAUSAS				
- Instalación inicial de la red sin la supervisión de un profesional certificado en estándares de cableado estructurado. - Falta de presupuesto para completar la instalación de canaletas y la adquisición de patch panels y rosetas. - Desconocimiento de los estándares ANSI/TIA/EIA por parte del personal que ha manipulado la red.				
EVIDENCIA				
- Fotografías del cableado expuesto, torceduras y conectores RJ45 colgando. - Checklist Módulo II (Cableado y Canalización) y Módulo III (Área de Trabajo), con múltiples criterios evaluados negativamente.				
IMPACTO				
- Alta probabilidad de rotura de conductores y fallos intermitentes de conectividad. - Daño a los puertos de los switches por la tensión del cable sólido horizontal. - Dificultad para realizar tareas de mantenimiento y una imagen de desorden generalizada.				
VALORACIÓN DEL RIESGO				
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo	
R-RED-009: Interrupción de conectividad por daño al cableado expuesto	Medio (2)	Alta (4)	Alto (8)	
RECOMENDACIONES				
- Corto plazo (30-60 días): Completar la instalación de canaletas plásticas en las diez áreas que carecen de protección. - Corto plazo: Instalar patch panels de 24 puertos en ambos nodos y rosetas de pared en todas las áreas de trabajo. - Corto plazo: Adquirir y utilizar patch cords flexibles de fábrica para la conexión final.				

SILAIS – SEDE MASAYA		REF: H-RED-INFRA-03		
HALLAZGOS DE LA AUDITORIA		H3		
PROCESO AUDITADO	Gestión operativa de la red – Rendimiento y capacidad	PAGINA		
		1	DE	1
RESPONSABLE				
CRITERIO	ISO 27001 A.17.2.1, COBIT DSS01, Normativa SISNIVEN			
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS01 – Gestión de Operaciones	
DESCRIPCIÓN DEL HALLAZGO				
Mediante la evaluación técnica utilizando comandos de diagnóstico del sistema operativo (ipconfig) y pruebas de rendimiento de Throughput con la herramienta de software iPerf3, se verificó que la velocidad de negociación de todos los enlaces de la red LAN está estancada en 100 Mbps. Esta limitación técnica está impuesta directamente por la obsolescencia de los Switches Fast Ethernet no administrables que fungen como núcleo de la red, los cuales generan un estrangulamiento operativo crónico. Como resultado, las estaciones de trabajo modernas del SILAIS, que están equipadas con tarjetas de red Gigabit (1000 Mbps), están operando apenas a un 10% de su capacidad física, restringiendo severamente el rendimiento de aplicaciones críticas y ralentizando la transmisión de datos epidemiológicos del SISNIVEN hacia el MINSA Central.				
CAUSAS				
• Obsolescencia tecnológica de los switches Fast Ethernet no administrables. • Falta de un plan de renovación tecnológica de la infraestructura de red. • Ausencia de monitoreo de rendimiento que hubiera permitido detectar el cuello de botella de forma proactiva.				
EVIDENCIA				
• Verificación del adaptador de red en las estaciones de trabajo de áreas críticas, confirmando la negociación forzada a 100 Mbps. • Registros (logs) de las pruebas de rendimiento de ancho de banda local realizadas con iPerf3 entre estaciones de trabajo. • Inspección visual y documentación de las fichas técnicas de los switches actuales, confirmando que sus puertos físicos no soportan el estándar Gigabit. • Entrevistas documentadas con los usuarios de áreas críticas (Estadística, Epidemiología) que reportan caídas de conexión y lentitud severa durante el envío de reportes al SISNIVEN.				
IMPACTO				
• Limitación del rendimiento de todas las aplicaciones de red, ralentizando la transferencia de datos epidemiológicos y administrativos. • Imposibilidad de implementar servicios que requieran un mayor ancho de banda. • Desaprovechamiento de la inversión en estaciones de trabajo con capacidad Gigabit.				
VALORACIÓN DEL RIESGO				
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo	
Proceso DSS01 no implementado: Estrangulamiento crónico del rendimiento de la red	Medio (2)	Muy Alta (5)	Alto (10)	
RECOMENDACIONES				
1. Prioritaria (30-60 días): Reemplazar los switches Fast Ethernet por switches Gigabit administrables para eliminar el cuello de botella. 2. Corto plazo: Implementar un sistema de monitoreo de ancho de banda para establecer una línea base de rendimiento y verificar la mejora tras el reemplazo.				

HALLAZGOS DE ARQUITECTURA LÓGICA Y SEGURIDAD DE RED

SILAIS – SEDE MASAYA			REF: H-RED-LOG-01		
HALLAZGOS DE LA AUDITORIA			H4		
PROCESO AUDITADO	Seguridad de las comunicaciones – Segmentación de red		PAGINA		
			1	DE	1
RESPONSABLE					
CRITERIO	ISO 27001 A.13.1.1, COBIT DSS05, Ley 921				
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS05 – Gestión de Servicios de Seguridad		
DESCRIPCIÓN DEL HALLAZGO					
La red LAN del SILAIS – Sede Masaya opera bajo una topología de red plana sin segmentación VLAN. Todas las áreas funcionales, incluyendo áreas críticas que manejan datos sensibles (Epidemiología, Banco Biológico), comparten el mismo dominio de broadcast con áreas administrativas y de uso compartido. Los switches Fast Ethernet, al no ser administrables, carecen de la capacidad técnica para implementar VLANs o listas de control de acceso.					
CAUSAS					
• Obsolescencia tecnológica de los switches Fast Ethernet, que no soportan la funcionalidad de segmentación lógica. • Falta de un diseño de arquitectura de red que contemple la separación por niveles de sensibilidad de datos. • Inexistencia de políticas de seguridad de la información que exijan la segmentación como control.					
EVIDENCIA					
• Pruebas de conectividad (comando ping) exitosas entre equipos de "Varios 1" y equipos de "Epidemiología" y "Banco Biológico", confirmando la ausencia de restricciones. • Checklist Módulo IV (Arquitectura Lógica), criterio S-02: ¿Están configuradas Redes Virtuales (VLANs)? Respuesta: NO.					
IMPACTO					
• Movimiento lateral sin restricciones para malware; un ataque de ransomware originado en un área de uso compartido puede cifrar datos en áreas críticas. • Acceso no autorizado a datos sensibles de pacientes desde cualquier punto de la red. • Incumplimiento de la Ley 921 de Protección de Datos Personales.					
VALORACIÓN DEL RIESGO					
Riesgo Asociado		Impacto	Probabilidad	Nivel de Riesgo	
R-RED-002: Cifrado de datos SISNIVEN por ransomware propagado en red plana		Catastrófico (5)	Alta (4)	Extremo (20)	
RECOMENDACIONES					
1. Prioritaria (30-60 días): Reemplazar los switches Fast Ethernet por switches Gigabit administrables con soporte para VLANs (802.1Q). 2. Al momento del reemplazo: Configurar la segmentación VLAN para aislar el tráfico de las áreas críticas (Epidemiología, Banco Biológico) del resto de la red. 3. Implementar Listas de Control de Acceso (ACLs) entre las VLANs para reforzar la seguridad.					

SILAIS – SEDE MASAYA			REF: H-RED-LOG-02		
HALLAZGOS DE LA AUDITORIA			H5		
PROCESO AUDITADO	Seguridad de la red – Gestión de conexiones externas		PAGINA		
			1	DE	1
RESPONSABLE					
CRITERIO	ISO 27001 A.13.1.1, COBIT DSS05				
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS05 – Gestión de Servicios de Seguridad		
DESCRIPCIÓN DEL HALLAZGO					
Se identificaron conexiones privadas a Internet operando en las áreas de Sindicato, SNC y Transporte, las cuales funcionan de manera independiente a la red corporativa del SILAIS. Estas conexiones no cuentan con autorización formal documentada, no están integradas en la red corporativa mediante una VLAN de invitados, y no se les aplica ningún tipo de monitoreo de tráfico o control de seguridad (filtrado de contenido, prevención de intrusiones).					
CAUSAS					
- Inexistencia de una política institucional que regule la instalación y el uso de conexiones a Internet alternativas. - Falta de un administrador de red que unifique y controle todos los puntos de acceso a Internet. - Percepción de estas áreas como "independientes" desde el punto de vista administrativo.					
EVIDENCIA					
- Entrevistas con los responsables de Sindicato, SNC y Transporte, quienes confirmaron la existencia y el pago independiente de estas conexiones. - Inspección física de los routers/módems de conexión privada en las áreas mencionadas. - Documentación inexistente sobre la autorización de estas conexiones por parte de la Dirección.					
IMPACTO					
- Creación de puntos de fuga de información no controlados hacia el exterior. - Bypass de todos los controles de seguridad corporativos, exponiendo al SILAIS a ataques externos sin posibilidad de detección. - Imposibilidad de auditar el tráfico de estas conexiones para cumplir con la Ley 921 de Protección de Datos Personales.					
VALORACIÓN DEL RIESGO					
Riesgo Asociado		Impacto	Probabilidad	Nivel de Riesgo	
R-RED-010: Fuga de información institucional a través de conexiones no monitoreadas		Crítico (4)	Baja (2)	Alto (8)	
RECOMENDACIONES					
- Corto plazo (30-60 días): Evaluar la integración de estas conexiones a la red corporativa. La mejor práctica es unificarlas bajo un único proveedor de servicios y segmentarlas en una VLAN de invitados con acceso solo a Internet y sin visibilidad de la red interna. - Mientras no se integren: Formalizar su existencia mediante una autorización de la Dirección y aplicarles medidas de seguridad básicas como cambio de contraseñas por defecto y filtrado de contenido.					

SILAIS – SEDE MASAYA			REF: H-RED-LOG-03		
HALLAZGOS DE LA AUDITORIA			H6		
PROCESO AUDITADO	Seguridad de la red inalámbrica		PAGINA		
			1	DE	1
RESPONSABLE					
CRITERIO	ISO 27001 A.11.2.2, COBIT DSS05				
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS05 – Gestión de Servicios de Seguridad		
DESCRIPCIÓN DEL HALLAZGO					
Catorce equipos en áreas funcionales críticas (Estadística, Contabilidad, Insumos Médicos, Enfermería y RRHH) dependen exclusivamente de conectividad WiFi para sus operaciones, sin disponer de puntos de red cableada como respaldo. Adicionalmente, se desconoce la configuración de seguridad de la red inalámbrica, ya que no existe documentación sobre el protocolo de cifrado (WPA2, WPA3), el mecanismo de autenticación utilizado ni la intensidad de la señal en los puntos de trabajo.					
CAUSAS					
- Planificación de la infraestructura de conectividad sin considerar la redundancia en áreas críticas. - Instalación de puntos de acceso WiFi sin el tendido paralelo de cableado UTP. - Ausencia de una gestión proactiva de la red que evalúe y documente las configuraciones de seguridad.					
EVIDENCIA					
- Tabla de distribución de conectividad por área funcional, que documenta la dependencia WiFi. - Checklist Módulo III, criterio E-06: ¿Las áreas críticas cuentan con puntos de red cableada como respaldo? Respuesta: NO.					
IMPACTO					
- Interrupción de la conectividad en procesos críticos de consolidación de datos estadísticos y gestión de inventario farmacéutico ante una caída de la señal WiFi. - Riesgo de interceptación de tráfico sensible (Man-in-the-Middle) si el protocolo de cifrado es débil o inexistente.					
VALORACIÓN DEL RIESGO					
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo		
R-RED-004: Interceptación de credenciales y datos vía WiFi	Crítico (4)	Media-Alta (4)	Extremo (16)		
R-RED-006: Exposición de datos por WiFi con cifrado débil	Alto (3)	Media (3)	Alto (9)		
RECOMENDACIONES					
- Corto plazo (30-60 días): Instalar puntos de red cableada como conexión principal en las áreas críticas, dejando la conectividad WiFi como respaldo. - Inmediata (0-15 días): Verificar y documentar el protocolo de cifrado y autenticación de los puntos de acceso; si es inferior a WPA2, planificar su actualización a WPA3.					

HALLAZGOS DE GESTIÓN Y GOBERNANZA DE LA RED

SILAIS – SEDE MASAYA		H-RED-GOB-01		
HALLAZGOS DE LA AUDITORIA		H7		
PROCESO AUDITADO	Gestión de Incidentes de Red		PAGINA	
			1	DE 1
RESPONSABLE				
CRITERIO	ISO 27001 A.16.1, COBIT DSS02			
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS02 – Gestión de Solicitudes e Incidentes	
DESCRIPCIÓN DEL HALLAZGO				
No existe un procedimiento formal ni una herramienta (como un sistema de tickets) para el registro, seguimiento y resolución de incidentes de red. Las fallas de conectividad se reportan de manera verbal o informal a personas que, sin designación oficial, intentan resolverlas. No se genera documentación que permita analizar la recurrencia de los problemas.				
CAUSAS				
• Inexistencia de un administrador de red responsable de la gestión de incidentes. • Falta de implementación de un sistema de mesa de ayuda básico. • Cultura organizacional reactiva que no prioriza el registro de eventos.				
EVIDENCIA				
• Entrevistas con el personal de las áreas de Epidemiología, Estadística y Planificación, quienes confirmaron el procedimiento informal. • Checklist de gestión de red, criterio DSS02: ¿Existe un registro formal de incidentes de red? Respuesta: NO.				
IMPACTO				
• Tiempos de respuesta y resolución de fallos excesivos y no controlados. • Imposibilidad de identificar problemas recurrentes o medir la calidad del servicio de red. • Sensación de desamparo en los usuarios al no tener un canal claro de reporte.				
VALORACIÓN DEL RIESGO				
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo	
Proceso DSS02 no implementado: Respuesta ineficiente a incidentes	Alto (3)	Muy Alta (5)	Alto (15)	
RECOMENDACIONES				
1. Corto plazo: Designar al responsable de red como punto único de contacto para el reporte de incidentes. 2. Corto plazo: Implementar un sistema de tickets simple (puede ser una hoja de cálculo compartida o una herramienta gratuita) para registrar, dar seguimiento y documentar la resolución de cada incidente.				

SILAIS – SEDE MASAYA			H-RED-GOB-02		
HALLAZGOS DE LA AUDITORIA			H8		
PROCESO AUDITADO	Gestión de la Continuidad de la Red		PAGINA		
			1	DE	1
RESPONSABLE					
CRITERIO	COBIT DSS04, ISO 27001 A.17.2				
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS04 – Gestión de la Continuidad		
DESCRIPCIÓN DEL HALLAZGO					
El SILAIS – Sede Masaya no cuenta con un Plan de Continuidad de Negocio o Recuperación ante Desastres (BCP/DRP) para la infraestructura de red. No existen procedimientos documentados que describan las acciones a tomar para restablecer la conectividad en caso de un fallo catastrófico del switch principal, la pérdida del enlace con el MINSA Central o cualquier otro incidente que paralice las comunicaciones.					
CAUSAS					
• Inexistencia de un responsable de TI que impulse la elaboración del plan. • Falta de conciencia sobre la dependencia crítica de la institución en la conectividad de red para la operación del SISNIVEN. • Ausencia de una política institucional de continuidad del negocio.					
EVIDENCIA					
• Respuesta negativa a la solicitud de documentación del BCP/DRP. • Entrevistas con el Director General y el Responsable de Planificación, quienes confirmaron su inexistencia.					
IMPACTO					
• Ante un fallo grave, la respuesta será improvisada, con tiempos de restauración de días. • Parálisis en la capacidad de reportar datos de vigilancia epidemiológica al MINSA Central. • Incumplimiento de la normativa de disponibilidad del SISNIVEN.					
VALORACIÓN DEL RIESGO					
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo		
R-RED-001: Colapso total de la LAN por fallo catastrófico	Catastrófico (5)	Alta (4)	Extremo (20)		
RECOMENDACIONES					
1. Inmediato (0-15 días): Convocar a un grupo de trabajo multidisciplinario para la elaboración del Plan de Continuidad y Recuperación ante Desastres de la red. 2. Corto plazo (30-60 días): Documentar el plan, definiendo roles, procedimientos de recuperación, RTOs (Recovery Time Objectives) y un listado de contactos de emergencia. Realizar una prueba de escritorio del plan.					

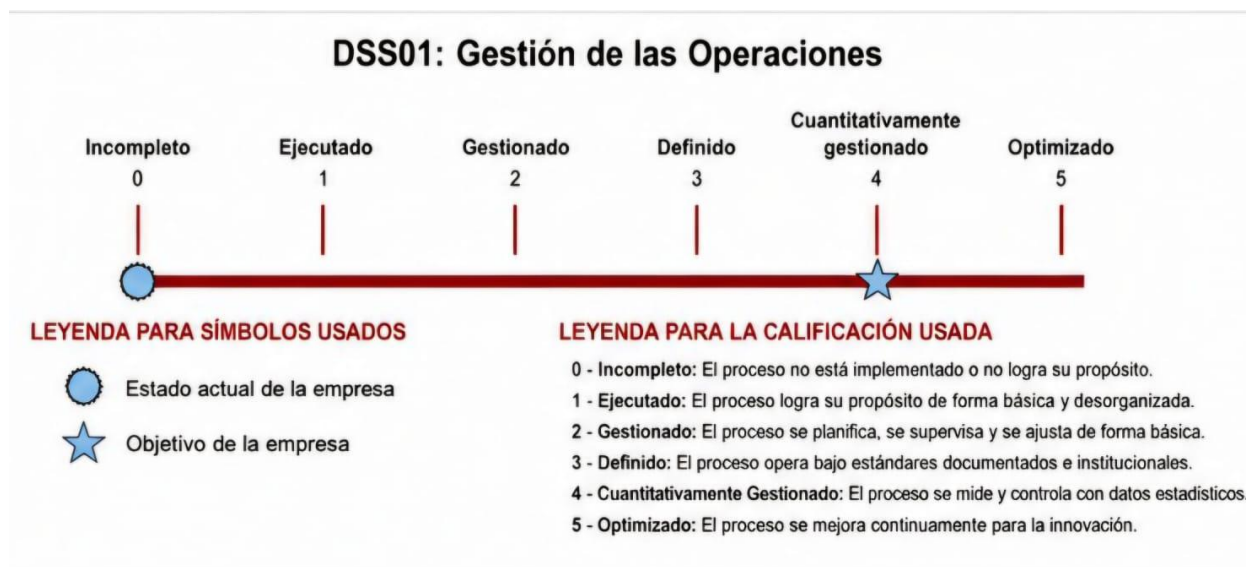
SILAIS – SEDE MASAYA		H-RED-GOB-03		
HALLAZGOS DE LA AUDITORIA		H9		
PROCESO AUDITADO	Gestión de Problemas de Red	PAGINA		
		1	DE	1
RESPONSABLE				
CRITERIO	ISO 27001 A.16.1, COBIT DSS03			
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS03 – Gestión de Problemas	
DESCRIPCIÓN DEL HALLAZGO				
No se evidencia la existencia de un proceso de Gestión de Problemas. Los incidentes de red (como caídas de WiFi o lentitud) se resuelven de manera reactiva, pero no se realiza un análisis estructurado de la causa raíz para identificar y erradicar los problemas subyacentes. Las soluciones aplicadas son, por lo general, temporales o se enfocan en restaurar el servicio, sin documentar acciones para prevenir la recurrencia.				
CAUSAS				
- Inexistencia de personal formalmente designado para la gestión de la red en todos sus niveles (no solo reactivo). - Confusión entre los procesos de Gestión de Incidentes (DSS02) y Gestión de Problemas (DSS03). - Falta de una metodología para el análisis de causa raíz (Diagrama de Ishikawa, 5 Porqués).				
EVIDENCIA				
- Entrevistas con el personal que eventualmente brinda soporte. - Ausencia de documentación que demuestre análisis de fallos recurrentes (ej. reportes de causa raíz). - Checklist de gestión de red, criterio DSS03: ¿Se realiza análisis de problemas recurrentes? Respuesta: NO.				
IMPACTO				
- Fallos recurrentes que afectan la productividad y la continuidad operativa. - Inversión de tiempo y recursos en "apagar incendios" en lugar de resolver problemas de fondo. - Prolongación de los tiempos de indisponibilidad de la red al no atacar las causas raíz.				
VALORACIÓN DEL RIESGO				
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo	
Proceso DSS03 no implementado: Cronificación de fallos de red por falta de solución definitiva	Alto (3)	Muy Alta (5)	Alto (15)	
RECOMENDACIONES				
- Corto plazo: Instituir formalmente la práctica de realizar un análisis de causa raíz para todo incidente de red que se repita o que tenga un impacto mayor. - Corto plazo: El responsable de la red deberá crear y mantener un registro de problemas (KDB, Known Error Database) que documente las soluciones definitivas a fallos recurrentes.				

SILAIS – SEDE MASAYA		H-RED-GOB-04		
HALLAZGOS DE LA AUDITORIA		H10		
PROCESO AUDITADO	Gestión de Riesgos de la Red		PAGINA	
			1	DE 1
RESPONSABLE				
CRITERIO	COBIT DSS03, DSS05, ISO 27001 A.13.1, A.16.1			
DOMINIO	DSS (Entregar, Dar Servicio y Soporte)	PROCESO	DSS03 – Gestión de Problemas / DSS05 – Gestión de Servicios de Seguridad	
DESCRIPCIÓN DEL HALLAZGO				
El SILAIS – Sede Masaya no cuenta con un proceso formal de gestión de riesgos de la infraestructura de red. No se ha establecido un marco para la identificación, análisis, evaluación y tratamiento de los riesgos técnicos (obsolescencia de switches, topología de red plana, dependencia WiFi) ni de los riesgos de seguridad de la información. Los riesgos identificados en la presente auditoría no forman parte de un registro oficial ni son monitoreados periódicamente por la institución.				
CAUSAS				
- Ausencia de un responsable de TI o de un comité de seguridad que impulse la gestión de riesgos. - Falta de conocimiento sobre metodologías de análisis de riesgos como ISO 27005. - La gestión de la red ha estado enfocada en la operación diaria, sin una visión estratégica de gobierno.				
EVIDENCIA				
- Respuesta negativa a la solicitud de documentación de un registro o matriz de riesgos de TI. - Entrevistas con la Dirección y Planificación, confirmando la inexistencia del proceso. - Los riesgos presentados en el diagnóstico (R-RED-001 a R-RED-017) fueron identificados por el equipo auditor, no por la institución.				
IMPACTO				
- La Alta Dirección carece de visibilidad sobre los riesgos tecnológicos que amenazan la continuidad del SISNIVEN. - Las decisiones de inversión en TI no se basan en un perfil de riesgo documentado. - Los riesgos de nivel "Extremo" permanecen sin un plan de tratamiento formal.				
VALORACIÓN DEL RIESGO				
Riesgo Asociado	Impacto	Probabilidad	Nivel de Riesgo	
Riesgo Global: Todos los riesgos identificados, al no ser gestionados formalmente, tienen una mayor probabilidad de materializarse	Catastrófico (5)	Alta (4)	Extremo (20)	
RECOMENDACIONES				
- Inmediato (0-15 días): Adoptar formalmente la Matriz de Riesgos de Red generada en esta auditoría como el punto de partida del registro de riesgos. - Corto plazo (30-60 días): Asignar al futuro responsable de TI la tarea de facilitar e implementar un proceso de gestión de riesgos (alineado a ISO 27005). Este proceso debe establecer la metodología, las responsabilidades y la periodicidad de la revisión de riesgos.				

Controles Efectivos Identificados (Aspectos que Cumplen)

1. **Filtrado DNS activo (Cloudflare 1.1.1.3):** Se verificó mediante Wireshark que el servidor DHCP inyecta correctamente la dirección DNS de Cloudflare Families, lo cual constituye un control efectivo de mitigación de malware y filtrado de contenido, alineado con DSS05.
2. **Cifrado robusto en redes WiFi:** Se verificó mediante comandos netsh wlan que los Puntos de Acceso "SILAIS MASAYA DIR" e "INSUMOS2026" operan con autenticación WPA2-Personal y cifrado CCMP (AES), garantizando la confidencialidad del tráfico inalámbrico, en cumplimiento de DSS05 e ISO 27001 A.11.2.2.

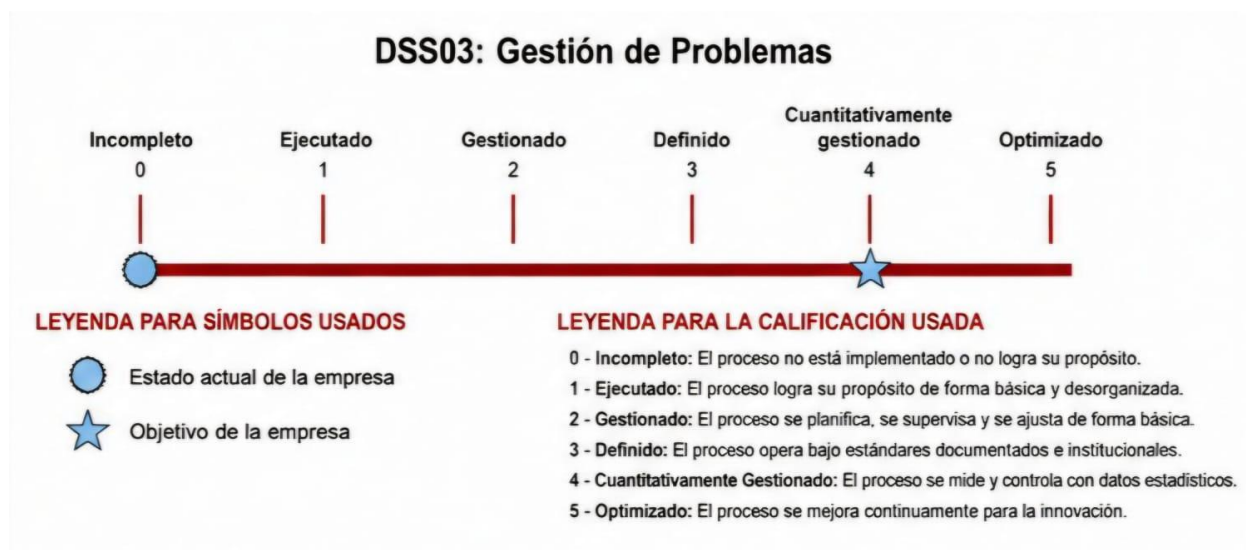
XI. NIVEL DE MADUREZ DE LOS PROCESOS DEL DOMINIO DSS



DSS01: Gestión de las Operaciones (Nivel 0 - Incompleto) El proceso carece de la base operativa mínima indispensable. Aunque existe transmisión de datos, el flujo se encuentra físicamente estrangulado a 100 Mbps debido a la obsolescencia de los equipos de conmutación (Switches Fast Ethernet). Esta limitante, sumada a las vulnerabilidades en el ponchado del cableado y la exposición de los gabinetes a condiciones ambientales críticas (polvo y falta de climatización), impide matemáticamente que el proceso consolide el nivel inicial, generando una brecha de capacidad crítica de -4 niveles.

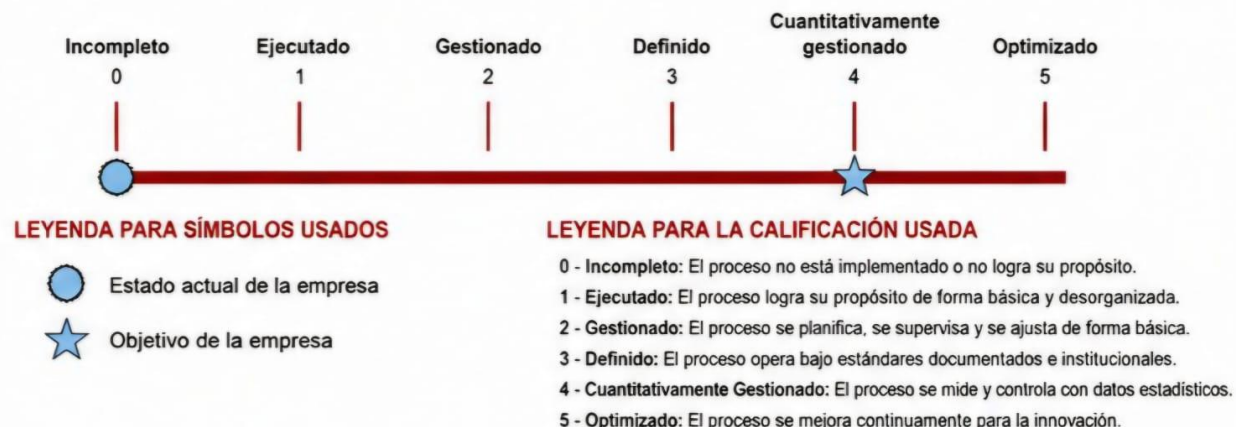


DSS02: Gestión de Peticiones e Incidentes de Servicio (Nivel 0 - Incompleto) La gestión de incidencias opera bajo un modelo empírico y desestructurado. Se constató la ausencia absoluta de un sistema formal de tickets (Service Desk) que permita el registro, clasificación, priorización y seguimiento de los fallos de red. Al depender exclusivamente de reportes verbales y del conocimiento no documentado del personal, el proceso es incapaz de medir sus tiempos de respuesta, resultando en un nivel de madurez nulo y una brecha de -4 frente al estándar exigido.

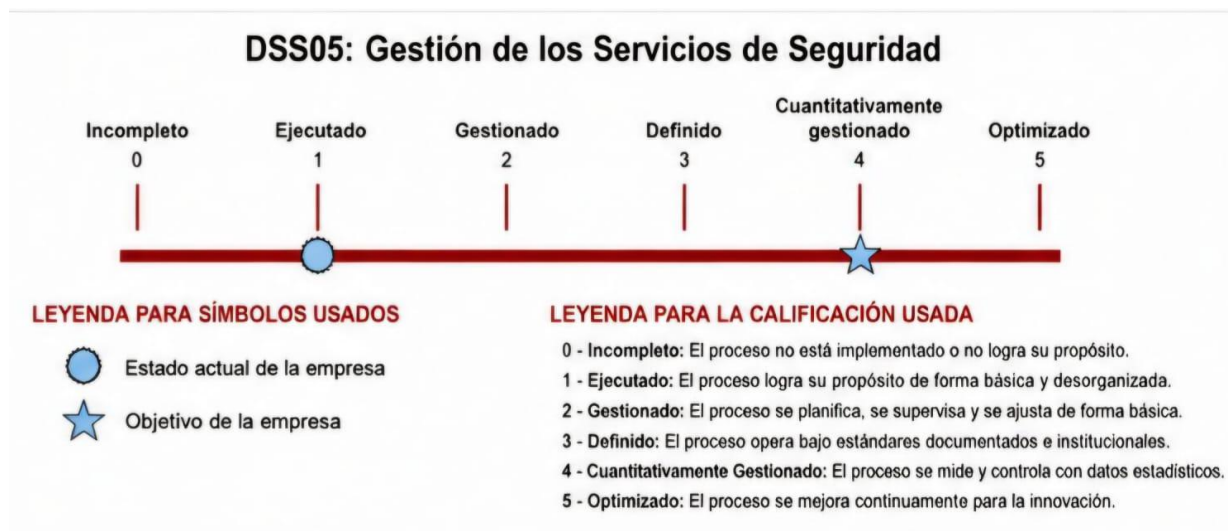


DSS03: Gestión de Problemas (Nivel 0 - Incompleto) La institución presenta un enfoque puramente reactivo, limitándose a tratar los síntomas (incidentes) sin erradicar la causa raíz (problemas). La auditoría determinó la falta de metodologías de diagnóstico estructurado (como el análisis de los 5 Porqués) y la inexistencia de una Base de Datos de Errores Conocidos (KDB). Al no investigar el origen de las fallas recurrentes de conectividad, el proceso se dictamina como Incompleto (Nivel 0), con una brecha de capacidad de -4.

DSS04: Gestión de la Continuidad



DSS04: Gestión de la Continuidad (Nivel 0 - Incompleto) Este proceso representa el vector de riesgo operativo más alto para la institución. Se evidenció la carencia total de un Plan de Recuperación ante Desastres (DRP) y de Políticas de Continuidad de Negocio (BCP) documentadas. Ante una falla catastrófica en el núcleo de la red física, el SILAIS Masaya no cuenta con tiempos objetivos de recuperación (RTO) ni redundancia, garantizando una parálisis prolongada en los sistemas de vigilancia epidemiológica (SISNIVEN). El nivel alcanzado es 0 (Incompleto), con una brecha de -4.



DSS05: Gestión de los Servicios de Seguridad (Nivel 1 - Ejecutado) Es el único proceso del dominio que logra superar el nivel nulo, alcanzando el Nivel 1 (Ejecutado). Esto obedece a la comprobación técnica de controles perimetrales efectivos, tales como la inyección automática de resolución DNS segura (mitigación de malware) y el uso de cifrado robusto (WPA2/CCMP) en redes inalámbricas. Sin embargo, el ascenso hacia un estado gestionado queda bloqueado por una vulnerabilidad estructural severa: la infraestructura opera como una "red plana". La ausencia de segmentación lógica (VLANs) facilita el movimiento lateral de amenazas, dejando una brecha de capacidad de -3 niveles frente a la meta global de seguridad.

XII. RESUMEN Y CONCLUSIONES

El presente apartado consolida los resultados de la Auditoría de Infraestructura de Redes, y Gobernanza de TI realizada en el **SILAIS – Sede Masaya**. El diagnóstico revela brechas significativas entre el estado operativo actual de la institución y los marcos normativos internacionales (ISO/IEC 27001, COBIT 2019, ANSI/TIA/EIA) y nacionales (Ley 921 de Protección de Datos Personales, Normativa SISNIVEN).

A. Infraestructura y Capa Física (Hardware y Cableado)

La infraestructura física de la red presenta un estado de deterioro y obsolescencia que contraviene los estándares de la industria:

- **Condiciones Ambientales y Eléctricas (H4):** El núcleo de red opera y está conectado a la red eléctrica sin protección industrial, incumpliendo la norma ANSI/TIA-569-C y el control ISO 27001 A.11.1.4.
- **Cableado Estructurado (H2):** La ausencia de canaletas en la mayoría de las áreas, combinada con la conexión directa de cables sólidos a los switches (sin patch panels ni rosetas), transgrede severamente las normativas ANSI/TIA-568-C y 569-C, elevando el riesgo de desconexiones físicas.
- **Rendimiento y Mantenimiento (H1, H3):** La red sufre un estrangulamiento crónico a 100 Mbps debido a switches Fast Ethernet obsoletos, limitando las capacidades de transmisión del SISNIVEN. Asimismo, la gestión de equipos es puramente reactiva, sin mantenimientos preventivos programados, lo cual es una no conformidad frente a COBIT DSS01 e ISO 27001 A.11.2.4.

B. Arquitectura Lógica y Seguridad de Red

Las configuraciones lógicas actuales exponen a la institución a riesgos cibernéticos extremos:

- **Segmentación Inexistente (H5):** La operación bajo una "red plana" permite que áreas administrativas y críticas (Epidemiología, Banco Biológico) compartan el mismo dominio de broadcast. Esto facilita el movimiento lateral de malware y expone datos sensibles de pacientes, incumpliendo la Ley 921 de Protección de Datos Personales e ISO 27001 A.13.1.1.
- **Fugas de Información y Conectividad (H6, H7):** La existencia de conexiones a Internet privadas y no monitoreadas (Sindicato, Transporte, SNC) actúa como un bypass a los controles corporativos. Simultáneamente, la alta dependencia de WiFi en áreas críticas, con cifrado desconocido, vulnera los controles de COBIT DSS05 y expone credenciales.

C. Gestión y Gobernanza de TI

El área tecnológica carece de procesos formales de administración, operando bajo un modelo "ad-hoc":

- **Gestión de Incidentes y Problemas (H8, H10):** No existe un sistema de *tickets* ni metodologías de análisis de causa raíz. La resolución de fallos es informal e indocumentada, lo que contraviene los procesos COBIT DSS02 y DSS03.
- **Continuidad y Riesgos (H9, H11):** La ausencia total de un Plan de Continuidad de Negocio (BCP/DRP) y de una Matriz de Riesgos deja a la Alta Dirección "a ciegas" ante un posible colapso total de las comunicaciones con el MINSA Central, fallando en los dominios estratégicos de COBIT DSS04, DSS05 e ISO 27001.

2. CONCLUSIONES GENERALES

1. **Alta Vulnerabilidad Operativa y Riesgo Extremo:** El SILAIS Masaya opera bajo un nivel de madurez tecnológica deficiente (Nivel 0-1 en la escala COBIT). La combinación de una topología de red plana, hardware de red obsoleto y condiciones ambientales adversas genera un entorno altamente propenso a fallos catastróficos que podrían paralizar la transmisión de reportes epidemiológicos nacionales (SISNIVEN).
2. **Incumplimiento Regulatorio y de Seguridad:** La falta de segmentación de red (VLANs) y la proliferación de conexiones privadas no autorizadas representan una amenaza directa a la confidencialidad de la información médica y administrativa, exponiendo a la institución a posibles penalizaciones por incumplimiento de la Ley 921.
3. **Cultura Reactiva sin Visión de Continuidad:** El soporte técnico se limita a "apagar incendios". La falta de un responsable de TI formalmente designado, sumada a la ausencia de planes de continuidad (DRP) y gestión de riesgos, impide que la tecnología funcione como un habilitador estratégico para la salud pública.

3. RECOMENDACIONES ESTRATÉGICAS (PLAN DE ACCIÓN)

Para mitigar los hallazgos descritos, se propone a la Dirección del SILAIS Masaya el siguiente plan de acción estructurado por prioridad:

Fase 1: Acciones Inmediatas (0 - 15 días) - Costo Cero o Bajo

- **Gobernanza:** Adoptar formalmente la Matriz de Riesgos elaborada en esta auditoría y convocar un comité para iniciar la redacción del Plan de Continuidad de Negocio (BCP/DRP).
- **Seguridad:** Auditar y actualizar inmediatamente las contraseñas y protocolos de cifrado de todos los Puntos de Acceso WiFi (exigir mínimo WPA2/WPA3). Formalizar o desconectar temporalmente las conexiones privadas de Internet.
- **Operaciones:** Designar un punto único de contacto (Responsable de Red) e implementar una herramienta gratuita de sistema de *tickets* para registrar incidentes.

Fase 2: Acciones a Corto Plazo (15 - 60 días) - Reordenamiento e Inversión Inicial

- **Renovación del Núcleo de Red:** Reemplazar los switches Fast Ethernet obsoletos por Switches Gigabit Administrables. Una vez instalados, configurar inmediatamente VLANs (802.1Q) para aislar el tráfico de las áreas críticas (Epidemiología, Banco Biológico) del resto de usuarios y de las conexiones de invitados.
- **Adecuación Física:** Instalar un sistema de aire acondicionado dedicado en el área de comunicaciones y separar los equipos del escritorio mediante un Gabinete (Rack) de pared.
- **Estandarización de Cableado:** Completar la instalación de canaletas plásticas, instalar patch panels en los nodos de distribución y colocar rosetas de pared en las áreas de trabajo, utilizando patch cords de fábrica para la conexión final a las PCs.

Fase 3: Acciones a Mediano Plazo (2 - 6 meses) - Madurez Tecnológica

- **Redundancia:** Instalar puntos de red cableada en las 14 áreas críticas que actualmente dependen exclusivamente de WiFi, dejando la conexión inalámbrica solo como respaldo.
- **Protección Eléctrica y Monitoreo:** Evaluar la adquisición de un sistema centralizado de acondicionamiento de energía (supresores de picos industriales) e implementar un sistema de monitoreo ambiental y de ancho de banda de red (PRTG o Zabbix) para establecer una línea base de rendimiento.

- **Mantenimiento:** Formalizar un cronograma de mantenimiento preventivo semestral estricto para el hardware de red y las UPS.

XIII. ANEXOS

Anexo 1. Organigrama del SILAIS Sede Masaya



Anexo 2. Listado de verificación (Checklist) – Auditoria de red y hardware de red

SILAIS - SEDE MASAYA

MÓDULO I: INFRAESTRUCTURA FÍSICA DE RED Y ÁREA DE COMUNICACIONES

Referencia Normativa: ANSI/TIA/EIA-569 (Espacios y Canalizaciones), ANSI/TIA/EIA-568-C (Cableado Comercial) e ISO/IEC 27001:2022 (A.11 Seguridad Física).

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
F-01	¿Los equipos de red centrales (Switch Principal de 24 puertos ubicado en Dirección y Switch Secundario de 24 puertos ubicado en Varios 1) están alojados de forma segura dentro de un Gabinete o Rack cerrado con llave?	ISO 27001 (A.11.1.1)	☐	☐	☐	
F-02	¿Existe un Patch Panel para la terminación mecánica del cableado rígido que proviene de las 14 áreas funcionales, o los cables están terminados directamente con conectores RJ45 hacia los switches?	ANSI/TIA-568-C	☐	☐	☐	
F-03	¿La distribución de energía para los switches se realiza a través de una regleta de alimentación segura o PDU, con protección contra sobrecargas?	TIA-942 / ISO 27001 (A.11.2.2)	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
F-04	¿Cada switch cuenta con respaldo de energía ininterrumpida mediante una UPS operativa y con baterías en buen estado?	ISO 27001 (A.11.2.2)	☐	☐	☐	
F-05	¿El área donde se ubican los switches (Dirección y Varios 1) cuenta con ventilación adecuada y está libre de acumulación de polvo volcánico?	ANSI/TIA-569-C	☐	☐	☐	
F-06	¿Los switches están ubicados sobre una superficie estable y segura, o sobre escritorios de madera expuestos a manipulación accidental?	ISO 27001 (A.11.1.3)	☐	☐	☐	
F-07	¿Se ha verificado visualmente el estado de los LEDs de diagnóstico de los switches (Power, Link/Act) para confirmar operación normal?	Mejores Prácticas	☐	☐	☐	

MÓDULO II: SUBSISTEMA DE CABLEADO HORIZONTAL Y CANALIZACIÓN

Referencia Normativa: ANSI/TIA/EIA-568-C (Cableado Comercial) y ANSI/TIA/EIA-569-C (Canalizaciones y Espacios).

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
C-01	¿El 100% de la trayectoria de los cables que conectan las 14 áreas funcionales se encuentra protegida dentro de canaletas plásticas de PVC?	ANSI/TIA-569-C	☐	☐	☐	
C-02	¿Las áreas de Banco Biológico, Sindicato, Dirección y FET Salud cuentan con canaletas plásticas instaladas?	ANSI/TIA-569-C	☐	☐	☐	
C-03	¿Las 10 áreas funcionales restantes (Epidemiología, Varios 1, 2 y 3, Estadística, Contabilidad, RRHH, Insumos Médicos, Enfermería, Administración, Caja, SNC) cuentan con canaletas plásticas o tienen el cableado expuesto?	ANSI/TIA-569-C	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
C-04	¿Se respetan los radios de curvatura del cableado UTP en todas las trayectorias para evitar daños internos a los conductores?	ANSI/TIA-568-C	☐	☐	☐	
C-05	¿El cableado horizontal está correctamente etiquetado o identificado en ambos extremos (área de switch y área de trabajo)?	ANSI/TIA-606-B	☐	☐	☐	
C-06	¿Se utiliza cable UTP de categoría adecuada (Cat5e o superior) que soporte al menos 100 Mbps en todos los tendidos?	ANSI/TIA-568-C	☐	☐	☐	
C-07	¿Los cables están terminados directamente con conectores RJ45 macho hacia los switches, sin utilizar Patch Panels intermedios?	ANSI/TIA-568-C	☐	☐	☐	
C-08	¿Se han realizado	Mejores	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
	pruebas de continuidad con Cable Tester en los puntos de red de las áreas críticas (Epidemiología, Estadística, Banco Biológico, Contabilidad, Dirección)?	Prácticas				
C-09	¿La norma de ponchado utilizada en los conectores RJ45 corresponde a la configuración T568A en ambos extremos?	ANSI/TIA-568-C	☐	☐	☐	

MÓDULO III: ÁREA DE TRABAJO (ENDPOINTS) Y TERMINACIONES FÍSICAS

Referencia Normativa: ANSI/TIA/EIA-568-C (Área de Trabajo) y ANSI/TIA/EIA-606-B (Administración y Etiquetado).

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
E-01	¿Las áreas de trabajo cuentan con rosetas de pared (faceplates) o cajas de superficie donde se terminan los cables de red?	ANSI/TIA-568-C	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	Sí	NO	N/A	Observaciones / Hallazgos
E-02	¿Los puntos de red están terminados con conectores RJ45 hembra (jacks) montados en placa, o los cables cuelgan directamente de la pared con un conector RJ45 macho?	ANSI/TIA-568-C	☐	☐	☐	
E-03	¿La conexión final entre el punto de red de la pared y las computadoras se realiza utilizando Patch Cords flexibles de fábrica?	ANSI/TIA-568-C	☐	☐	☐	
E-04	¿Los puntos de red en las áreas de trabajo están etiquetados formalmente con una nomenclatura que permita identificar su ubicación en el switch o área correspondiente?	ANSI/TIA-606-B	☐	☐	☐	
E-05	¿Los 46 equipos de escritorio y 5 laptops tienen acceso físico a un punto de red o dependen exclusivamente de	Mejores Prácticas	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	Sí	NO	N/A	Observaciones / Hallazgos
	conectividad WiFi?					
E-06	¿Las áreas de Estadística (2 equipos WiFi), Contabilidad (3 equipos WiFi), Insumos Médicos (3 equipos WiFi), Enfermería (2 equipos WiFi) y RRHH (2 equipos WiFi) cuentan con puntos de red cableada como respaldo?	Mejores Prácticas	☐	☐	☐	

MÓDULO IV: ARQUITECTURA LÓGICA DE RED (CAPA 2 Y CAPA 3)

Referencia Normativa: ISO/IEC 27001:2022 (A.13 Seguridad de las Comunicaciones) y COBIT 2019 (DSS05 Gestión de Servicios de Seguridad).

ID	Criterio de Evaluación	Norma Aplicada	Sí	NO	N/A	Observaciones / Hallazgos
S-01	¿Los switches Fast Ethernet de 24 puertos son administrables y permiten la configuración de VLANs, QoS, seguridad de puertos y monitoreo?	ISO 27001 (A.13.1.1)	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
S-02	¿Están configuradas Redes Virtuales (VLANs) para separar el tráfico de datos sensibles (Epidemiología, Banco Biológico) del tráfico administrativo (Contabilidad, RRHH) y del tráfico de áreas de uso compartido (Varios 1, 2 y 3)?	ISO 27001 (A.13.1.1)	☐	☐	☐	
S-03	¿La topología de red actual es plana (un solo dominio de broadcast) sin segmentación lógica entre las 14 áreas funcionales?	ISO 27001 (A.13.1.3)	☐	☐	☐	
S-04	¿Se ha verificado la velocidad de negociación de los enlaces en los equipos de cómputo, confirmando que operan a 100 Mbps debido a la limitación de los switches Fast Ethernet?	Mejores Prácticas	☐	☐	☐	
S-05	¿El direccionamiento IP está correctamente	Mejores Prácticas	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	Sí	NO	N/A	Observaciones / Hallazgos
	configurado mediante DHCP o asignación estática documentada para todas las áreas?					
S-06	¿Existen Listas de Control de Acceso (ACLs) o reglas de firewall que restrinjan la comunicación entre áreas con diferentes niveles de sensibilidad de datos?	ISO 27001 (A.13.1.1)	☐	☐	☐	
S-07	¿La red inalámbrica (WiFi) utilizada en Estadística, Contabilidad, Insumos Médicos, Enfermería y RRHH cuenta con protocolo de cifrado WPA2 o superior?	ISO 27001 (A.11.2.2)	☐	☐	☐	
S-08	¿Se ha verificado la intensidad de señal WiFi en los puntos de trabajo de las áreas críticas, asegurando un nivel superior a -67 dBm?	Mejores Prácticas	☐	☐	☐	
S-09	¿Las conexiones	ISO	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	Sí	NO	N/A	Observaciones / Hallazgos
	privadas a Internet en Sindicato, SNC y Transporte están documentadas, autorizadas y cuentan con medidas de seguridad para prevenir fuga de información institucional?	27001 (A.13.1.1)				

MÓDULO V: SEGURIDAD DE LA INFORMACIÓN Y CONTROL DE ACCESO A LA RED

Referencia Normativa: ISO/IEC 27001:2022 (A.9 Control de Acceso, A.12 Seguridad de las Operaciones) y COBIT 2019 (DSS05).

ID	Criterio de Evaluación	Norma Aplicada	Sí	NO	N/A	Observaciones / Hallazgos
G-01	¿Existe un procedimiento formal para la autorización y registro de nuevos dispositivos que se conectan a la red del SILAIS?	ISO 27001 (A.9.1.1)	☐	☐	☐	
G-02	¿Se ha implementado control de acceso a la red mediante autenticación 802.1X o seguridad de puertos en los switches?	ISO 27001 (A.9.4.2)	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	Sí	NO	N/A	Observaciones / Hallazgos
G-03	¿Se monitorea el tráfico de red para detectar actividades anómalas, intentos de acceso no autorizado o saturaciones de ancho de banda?	ISO 27001 (A.12.4.1)	☐	☐	☐	
G-04	¿Existe un registro (bitácora) de incidentes de seguridad de red, incluyendo caídas de conectividad, lentitud extrema o intentos de intrusión?	ISO 27001 (A.16.1.5)	☐	☐	☐	
G-05	¿Se realizan copias de seguridad (backups) de las configuraciones de los dispositivos de red (switches, puntos de acceso)?	COBIT 2019 (DSS04)	☐	☐	☐	
G-06	¿Existe un Plan de Continuidad de Negocio o Recuperación ante Desastres que contemple el fallo de los switches principales o la pérdida de conectividad con el MINSA Central?	COBIT 2019 (DSS04)	☐	☐	☐	

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
G-07	¿Se dispone de un switch de respaldo para reemplazar rápidamente un equipo fallado y restablecer la conectividad en las áreas críticas?	COBIT 2019 (DSS04)	☐	☐	☐	

MÓDULO VI: GESTIÓN DE ACTIVOS DE RED Y DOCUMENTACIÓN

Referencia Normativa: COBIT 2019 (DSS01 – Gestión de Operaciones) e ISO/IEC 27001:2022 (A.8 Gestión de Activos).

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
A-01	¿Existe un inventario formal, actualizado y documentado de todos los activos de red (switches, UPS, puntos de acceso, cableado estructurado)?	COBIT 2019 (DSS01)	☐	☐	☐	La gestión de inventarios de infraestructura es una práctica operativa fundamental dentro de DSS01.

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
A-02	¿El inventario incluye información sobre: marca, modelo, número de serie, fecha de adquisición, estado de garantía y ubicación física de cada activo de red?	ISO 27001 (A.8.1.1)	☐	☐	☐	
A-03	¿Se ha definido un responsable o propietario para cada activo de red crítico?	ISO 27001 (A.8.1.2)	☐	☐	☐	
A-04	¿Existe un diagrama de topología de red actualizado que muestre la interconexión de los switches, puntos de acceso y la distribución hacia las 14 áreas funcionales?	Mejores Prácticas (alineado a DSS01)	☐	☐	☐	Mantener documentación actualizada de la topología es parte de la operación diaria (DSS01).
A-05	¿Se ha documentado la antigüedad y el ciclo de vida estimado de los switches Fast Ethernet para planificar su renovación tecnológica?	COBIT 2019 (DSS01)	☐	☐	☐	El seguimiento del ciclo de vida y la planificación del reemplazo se gestionan dentro de las operaciones (DSS01).

ID	Criterio de Evaluación	Norma Aplicada	SÍ	NO	N/A	Observaciones / Hallazgos
A-06	¿Existe un procedimiento formal para la baja y disposición segura de equipos de red obsoletos o dañados?	ISO 27001 (A.8.3.2), COBIT 2019 (DSS01)	☐	☐	☐	La disposición segura es una tarea operativa que debe estar documentada (DSS01).

Auditor Responsable: _____

Fecha de Verificación: _____ / _____ / 2026

Firma del Auditor: _____

Anexo 3. Evidencias de auditoria

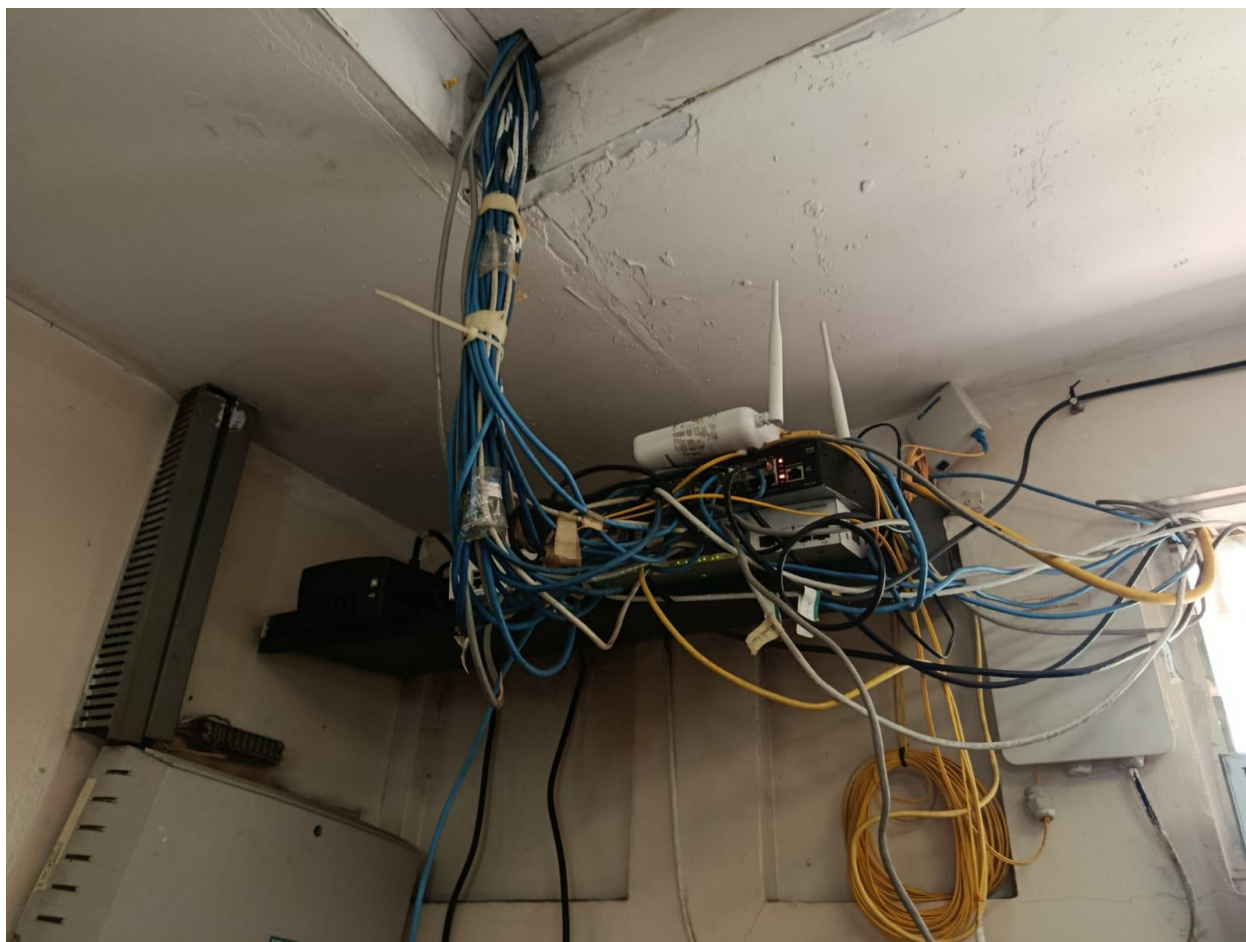


Imagen 1. Los dos switches principales ubicados en el área de Dirección no cuentan con un Rack ni con un patch panel.



Imagen 2. El tercer switch que se encuentra en la oficina 'Varios 1' no cuentan con un con un Rack ni con un patch panel.



Imagen 3. Cableado que conecta a la PC de la oficina Varios 1 y se usa para atención integral a la mujer, no cuenta con Patch Cord y el cableado está torcido.



Imagen 4. Cableado que conecta a la PC del componente de Crónicos y el programa Todo Con Vos, no cuenta con Patch Cord y el cableado está colgado y vulnerable a deteriorarse con mayor facilidad.

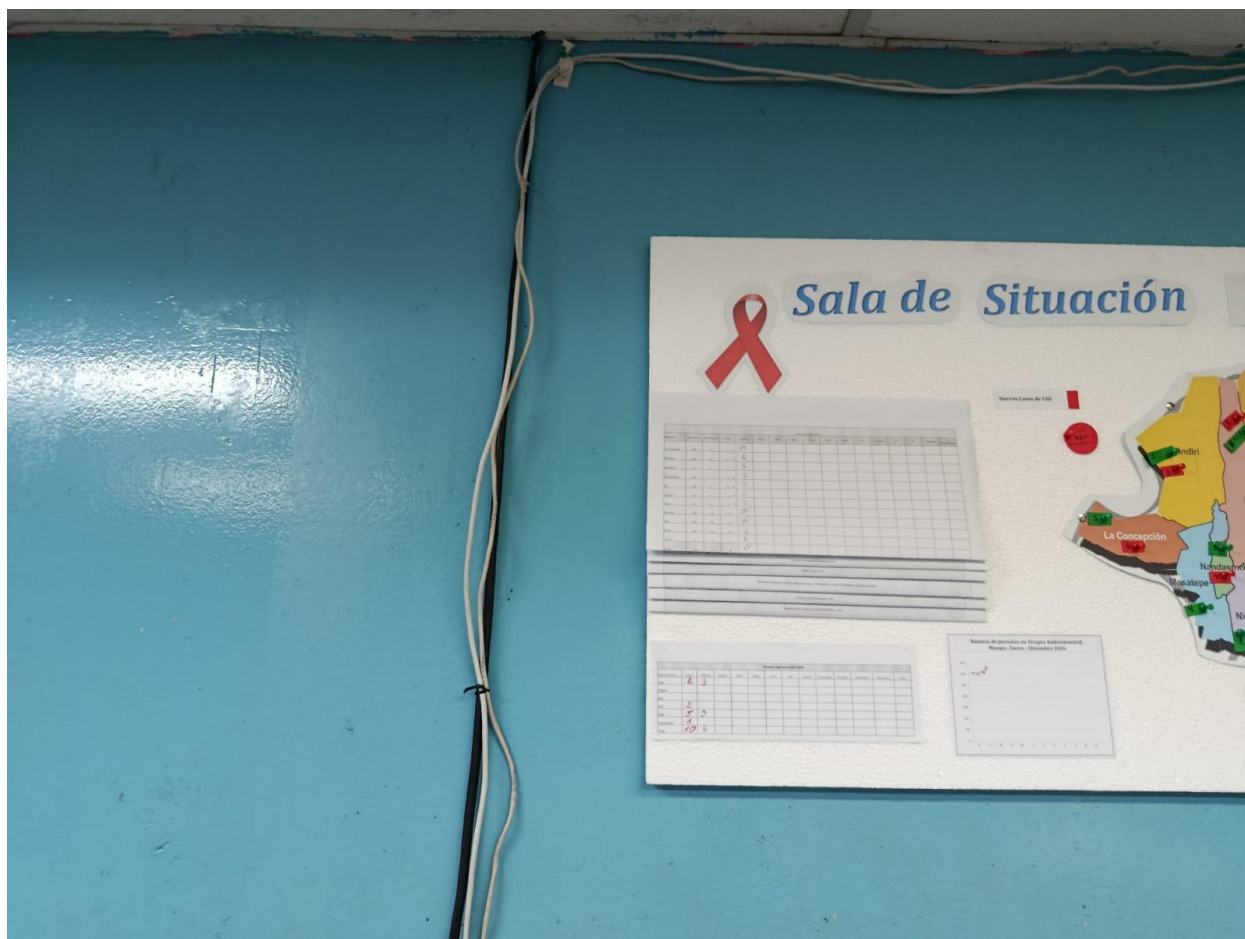


Imagen 5. Los cables no están dentro de una canaleta adosada a la pared, separados de cualquier cable eléctrico, sin estar estrangulados por cinchos plásticos y correctamente etiquetados.



Imagen 6. El cable de red de la oficina Varios 2 que conecta a la computadora usada por el componente VIH no cuenta patch cord.